

While LLMs represent an advancement in code generation, they exhibit several limitations that pose security risks. One concern is that, despite their proficiency in producing functional code, these models may generate code that violates secure-coding best practices [81]. Another concern is that LLMs are trained on enormous datasets, often gathered from unverified online platforms (e.g., GitHub [1] and HuggingFace [2]). This reliance on potentially insecure data introduces data poisoning risks, where an attacker inserts harmful data samples into the training set [19]. These and other shortcomings can lead LLMs to generate insecure code, as well as influence their abilities to detect and fix security vulnerabilities.

Regardless of the risks, LLMs are largely used for their code-related capabilities. Therefore, to take informed decisions, it is crucial for practitioners to have a clear understanding about the precise nature of risks and benefits. In this Systematic Literature Review (SLR), we aim to:

- Explore the potential security vulnerabilities introduced by LLM-generated code;
- Evaluate the effectiveness of LLMs in detecting and fixing vulnerabilities, as well as the prompting strategies used for these tasks;
- Investigate the effects of data poisoning on LLMs ability to produce secure code and to detect and fix vulnerabilities effectively.

1.1 Outline

This paper is organized as follows. Section 2 describes related works. Section 3 describes the methodology we followed in this work. Section 4 discusses the vulnerabilities identified in LLM-generated code, by the state of the art. Section 5 examines LLMs ability to detect code vulnerabilities, Section 6 their ability to fix pre-identified vulnerabilities, and Section 7 their potential to detect and fix vulnerabilities in a unified process. Furthermore, Section 8 covers prompting techniques used for vulnerability detection and fixing, as described by the studies covered in this review. Section 9 explores the impact of poisoned training data on LLMs ability to generate secure code, detect vulnerabilities, and fix them. Section 10 addresses the research questions, open challenges, and threats to validity. Finally, Section 11 concludes the paper.

2 Related Work

In recent years, the literature has focused on different aspects of the intersection between LLMs and code security. As we discussed in Section 1, in this SLR we focus on three main thematic areas. Although other surveys covered these areas, they all focused on only one (or two) areas at a time. To the best of our knowledge, this is the first comprehensive survey that addresses all three areas. Furthermore, this is the first paper to attempt to categorize the various vulnerabilities that can be introduced by LLMs. Among the surveys covered in this section, only Negri et al. [73] describe how LLMs often generate code containing specific vulnerabilities, but they did not provide a systematic categorization of such vulnerabilities. In contrast, our work organizes them into 10 distinct categories.

Other characteristics differentiate our paper from the current literature. First, while other surveys investigated the performance of LLMs for vulnerability detection and fixing, unified processes for addressing both tasks have not been surveyed. Second, no other survey investigates how the prompting strategy of choice impacts tasks related to code security. Yao et al. [119] reviewed various applications of LLMs in security, including vulnerability detection and fixing. Similarly, Sheng et al. [92] surveyed LLM-based software vulnerability detection, focusing on detection techniques, datasets, evaluation metrics, and open challenges. Taghavi et al. [97] reviewed models, methods, techniques, datasets, and metrics for LLM-based software vulnerability detection. Germano et al. [29] reviewed the use of LLMs for vulnerability detection, repair, and explanation in source

Table 1. Comparison of prior secondary studies on LLMs and code security. Each column indicates whether a review explicitly addresses the corresponding topic.

Secondary study	Month/Year	Vuln. categorization	Detect	Fix	Detect+Fix	Prompting	Poisoning
Negri et al. [73]	04/2024	✓					
Yao et al. [119]	01/2024		✓	✓			
Sheng et al. [92]	09/2025		✓				
Taghavi et al. [97]	01/2025		✓				
Germano et al. [29]	11/2025		✓	✓			
Zhou et al. [128]	11/2024		✓	✓		✓	
Chen et al. [18]	04/2025						✓
This SLR	01/2026	✓	✓	✓	✓	✓	✓

code, noting that most studies focus on vulnerability detection, with fewer addressing repair and explanation. However, as shown in Table 1, none of these reviews covers the full scope of our work, namely, secure code generation, unified detection and fixing, the impact of prompting strategies, and the role of data poisoning in code-security tasks. Although Zhou et al. [128] provided an overview of prompting techniques, listing which papers applied each technique for vulnerability detection and repair, their work did not investigate the impact of prompting techniques on such tasks, nor the merging of vulnerability detection and fixing in a unified process.

Furthermore, the literature only partially covers the impact of data poisoning attacks on LLMs code generation, and our work fills this gap by analyzing this potential impact. Yao et al. [119] introduce the threat of data poisoning attacks, but do not discuss the deeper effects of these attacks on LLMs secure code generation nor on vulnerability-related tasks. Similarly, Chen et al. [18] highlight the general consequences of poisoning attacks on general code generation tasks, including the effects on code summarization and code search, unrelated to the security focus of this review. In this paper, we provide an in-depth exploration of security-specific aspects, discussing how poisoning attacks influence the ability of LLMs to generate secure code, detect vulnerabilities, and propose fixes. More broadly, several surveys review LLMs across cybersecurity or software engineering tasks beyond code security [37, 116, 122, 123], falling outside of the scope of this paper.

Besides these differences in scope and thematic coverage, this SLR is further distinguished by the recency of the literature it synthesizes. To the best of our knowledge, our work incorporates all studies published through 2025 and into early 2026, whereas previous studies cover 2025 only partially (also shown in Table 1). In a fast-evolving area such as LLMs in code security, this more up-to-date coverage strengthens the relevance and timeliness of our synthesis.

3 Methodology

In this study, we conducted an SLR following established guidelines proposed by Petersen et al. [84]. Following the adopted guidelines, we carried out the review through three structured phases: planning, conducting, and reporting. In this section, we present the research questions, search strategy, selection criteria, study selection process, and the publication trends and venue distribution of the included studies.

3.1 Research Questions

We formulated the following Research Questions (RQs) to guide our investigation and help fulfill the aims of this study:

- **RQ1:** What security vulnerabilities in LLM-generated code have been reported in the current literature?
- **RQ2:** What is the state of the art on the capabilities and limitations of LLMs for detecting and fixing security vulnerabilities in code?
 - **RQ2.1:** Which prompting techniques are used in LLM-based detection and fixing of security vulnerabilities in code, and how do these techniques affect model performance?
- **RQ3:** What effects of poisoned training data on LLMs ability to generate secure code, detect vulnerabilities, and fix them have been reported in the current literature?

3.2 Search Strategy

To address the RQs, we developed the following base search strings for the automated database search. We adapted them to accommodate database-specific syntax and query constraints while preserving their logical structure. The first search string addresses RQ1:

("Large Language Models" OR "Language Model" OR "LLMs" OR CodeX OR Llama OR Copilot OR GPT-* OR ChatGPT) AND ("Security Vulnerabilities" OR "Security Risks" OR "Security Flaws" OR "Software Security" OR "Impact On Code Security" OR Cybersecurity OR Vulnerabilities) AND ("Code Generation" OR "AI-generated Code" OR "Automated Code Generation")

The second search string is designed to address RQ2:

("Large Language Models" OR "Language Model" OR CodeX OR Llama OR Copilot OR GPT-* OR ChatGPT) AND ("Vulnerability Detection" OR "Bug Detection" OR "Security Flaw Detection" OR "Code Analysis" OR "Static Analysis" OR "Vulnerability Remediation" OR "Bug Fixing" OR "Automated Code Repair" OR "Security Patch" OR "Code Patching") AND (Prompt* OR "Prompt Engineering" OR "Prompting Strategy" OR "Prompt-based" OR "Zero-shot" OR "Few-shot" OR "One-shot" OR "Chain-of-Thought" OR "In-context")

Finally, the third search string is designed to address RQ3:

("Large Language Models" OR "Language Model" OR LLMs OR CodeX OR Llama OR Copilot OR GPT-* OR ChatGPT) AND ("Code Generation" OR "AI-generated Code" OR "Automated Code Generation") AND ("Security Vulnerabilities" OR "Security Risks" OR "Security Flaws" OR "Software Security" OR "Impact On Code Security" OR "Cybersecurity" OR Vulnerabilities) AND ("Training Data Poisoning" OR "Poisoned Datasets" OR "Data Poisoning Attacks" OR "Adversarial Attacks" OR "Malicious Training Data") AND ("Vulnerability Detection" OR "Bug Detection" OR "Security Flaw Detection" OR "Code Analysis" OR "Static Analysis" OR "Vulnerability Remediation" OR "Bug Fixing" OR "Automated Code Repair" OR "Security Patch" OR "Code Patching")

3.3 Selection Criteria

To ensure a relevant review of the literature, we defined inclusion and exclusion criteria. The detailed criteria for paper selection are outlined in Table 2. Given that the field is relatively new and has seen significant contributions in the last few years, we did not establish criteria for narrowing down the period of publications. We applied these inclusion and exclusion criteria throughout the study selection process, which is described in the following subsection.

3.4 Study Selection Process

We conducted an automated search across IEEE Xplore, ACM Digital Library, ScienceDirect, SpringerLink, and USENIX database. The search was executed between January 7 and January 12,

Table 2. Inclusion and exclusion criteria for paper selection.

Inclusion Criteria
IN1: Peer-reviewed full-text papers identified through the database search and snowballing.
IN2: Papers that specifically identify vulnerabilities in code generated by LLMs.
IN3: Papers that evaluate the capability of LLMs to detect and fix security vulnerabilities in code.
IN4: Papers that explore the impact of poisoned training data on LLMs ability to generate secure code and detect and fix vulnerabilities.
Note: To be included in the review, a paper must satisfy IN1 and (IN2 or IN3 or IN4) .
Exclusion Criteria
EX1: Papers not written in English.
EX2: Articles without accessible full-text versions.
EX3: Secondary studies, such as SLRs or surveys.
EX4: Papers that focus on LLM capabilities unrelated to security.
EX5: Studies evaluating only PLMs without involving LLMs, and studies in which the main proposed approach is based on PLMs rather than LLMs.
EX6: Studies centered on agent-based LLM systems.
EX7: Papers focusing exclusively on smart contract vulnerabilities.

2026. The study identification and screening procedure is reported using a PRISMA-based flow diagram [79], as shown in Figure 1.

We retrieved 7008 records from the automated search. After removing duplicates, we obtained 6072 unique records. We then conducted title screening in three steps. First, we excluded papers not related to LLMs, leaving 1473 records. Second, we excluded papers not related to security, reducing the set to 623 records. Third, we excluded secondary studies (e.g., surveys and SLRs), resulting in 595 papers that proceeded to abstract screening. We then screened abstracts and selected 218 studies for full-text assessment. After full-text review, we included 96 primary studies. Finally, backward snowballing identified 6 additional relevant papers, resulting in 102 included studies.

3.5 Publication Trends and Venue Distribution

Given the fast-evolving nature of this research area, we provide an overview of the included studies by examining their distribution over time and across publication venues.

As shown in Figure 2, the number of publications has increased in recent years. Only 4 studies were published between 2021 and 2022 (one in 2021 and three in 2022), followed by 12 studies in 2023. The number of publications increased further in 2024 and 2025, with 38 and 41 studies, respectively. The lower number observed for 2026 (7 studies) is expected because the search was conducted in January 2026 and therefore does not represent a complete publication year.

Figure 3 shows the distribution of studies across publication venues. IEEE venues account for the largest share of the included studies (48 papers), followed by ACM (23) and Springer (12). Elsevier, USENIX, and other venues contribute smaller numbers of studies (7, 6, and 6 papers, respectively). Overall, most of the included studies were published in IEEE and ACM venues.

4 Security Vulnerabilities Introduced by LLMs

Although LLMs became popular for their ability to generate functional code fast and speed up development, they can introduce security vulnerabilities that developers might miss, leading to risks regarding code integrity and safety [35]. In this section, we address RQ1 by focusing on

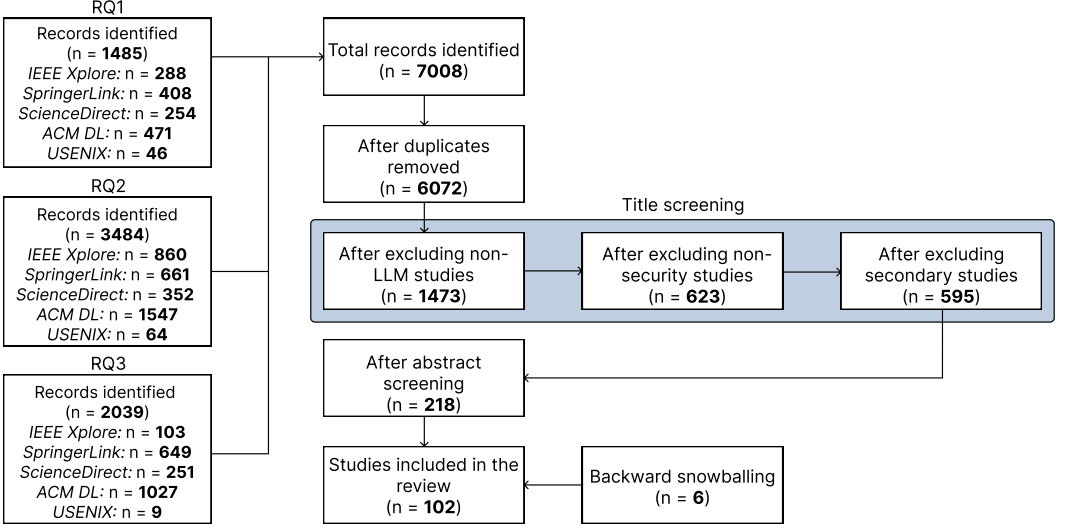


Fig. 1. PRISMA-based flow diagram of the study identification and screening process.

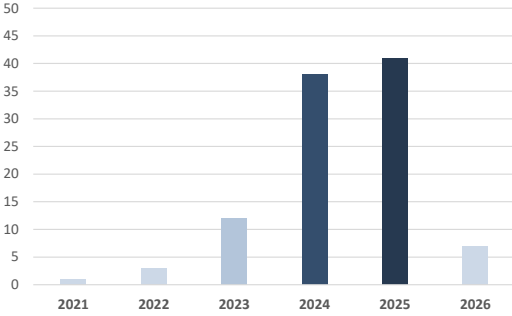


Fig. 2. Distribution of studies by publication year.

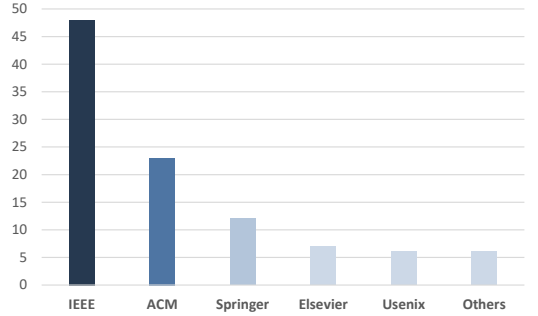


Fig. 3. Distribution of studies across venues.

specific vulnerabilities introduced by LLM-generated code, as identified in 21 studies, and on how these map to the Common Weakness Enumeration (CWE) taxonomy [70]. For each study, we extracted the reported vulnerabilities and grouped them into 10 categories that we defined for this SLR, which are summarized in Table 3. In each cell, we either list the CWE(s) reported in the study for that category or use a green checkmark (✓) to indicate that the study reported vulnerabilities belonging to that category without specifying the corresponding CWE identifiers.

We do not compare vulnerability rates across studies because the primary studies rely on different code-generation tasks, datasets, and evaluation setups, which makes rate-based comparisons inconsistent. We summarize the models, programming languages, and datasets used in each study in Appendix A (Table 6).

4.1 Injection Vulnerabilities

Injection vulnerabilities are identified across most of the reviewed studies, appearing in 17 papers. This category contains various types of vulnerabilities, including SQL injection, Cross-Site Scripting (XSS), OS command injection, and regular expression (regex) injection. Two studies focused on

Table 3. Vulnerability categories in LLM-generated code across the reviewed studies. Cells list CWE ID(s) when reported. Green checkmarks (✓) indicate the category was reported without specific CWE(s).

References	Injection	Memory Management	File Management	Deserialization	Sensitive Data Exposure	Authentication and Authorization	Cryptography	Resource Management	Coding Standards	Error Handling
[64]	78, 79, 89	119, 125, 190, 416, 476, 787	22, 434	502	200, 206	522, 798			20	
[47]	94, 564	190	35, 377	502	256		323, 338, 759	400	133, 453, 687	
[8]	707					284		664	682, 691, 710	
[83]	✓	✓	✓				✓			
[90]		401, 416, 476, 787							758	252
[81]	77, 78, 79, 89	119, 125, 190, 416, 476, 787	22, 434		200	306, 522, 798			20	
[94]	79, 918				208, 209, 215, 312	287, 798	295, 338			
[33]	79	190, 787	22						20	
[35]	78, 79, 89	125, 190, 476, 787	22							
[95]	79, 89, 94		22	502		297, 352, 601, 730	327		20, 611	
[105]	80, 83								20	
[103]		120, 129, 190, 191, 476, 761, 787, 788, 843							628	
[34]						798	327, 328	404, 772		
[87]	78, 94			502		259	327, 330	400, 605	20	703
[27]	78, 89, 94		22	502	215, 312	798	295	367, 772	369, 563, 617, 628	117
[36]	79, 89	119	22	502	200	352, 732, 915	295, 326, 327, 338		611	
[31]	78, 79, 80, 90, 94, 95, 99, 113, 116, 643, 918, 943		22, 377, 434, 641	502	200, 209, 215, 319, 385	250, 259, 269, 283, 285, 425, 522, 601, 732, 798, 841, 941	321, 326, 329, 330, 331, 759, 760, 1204	367, 400, 406, 414, 605, 776	454, 462, 595, 611, 827	252, 117
[41]	79, 89, 93				200					
[9]	79, 89, 94, 95, 78, 134, 601, 918		22		200, 208, 539	319, 384	327, 347, 916	606, 770	565, 1188, 1287, 1321, 1333	117, 614
[66]	78, 79, 89		22, 434	502	200	306, 522, 732				
[24]						259	327, 798, 330, 326			

injection vulnerabilities. Khoury et al. [47] conducted an experiment where they generated 21 programs in 5 different programming languages using GPT-3.5. The programs were intentionally diverse, each designed to highlight the risks associated with specific vulnerabilities. Among these, 6 programs targeted injection vulnerabilities. Notably, in every instance, GPT-3.5 failed to do proper input sanitization, resulting in various types of injection vulnerabilities. Similarly, Tóth et al. [105] focused on the security of 2500 PHP websites, generated by GPT-4. Using both dynamic and static scanners, manual code verification, and penetration testing, they identified various vulnerabilities, particularly concerning the security of file upload functions, as well as SQL injections and XSS.

The studies frequently identified the following injection-related CWEs: CWE-79: Improper Neutralization of Input During Web Page Generation (“Cross-site Scripting”) [9, 31, 33, 35, 36, 41, 64, 66, 81, 94, 95], and CWE-89: Improper Neutralization of Special Elements used in an SQL Command (“SQL Injection”) [9, 27, 35, 36, 41, 64, 66, 81, 95].

4.2 Memory Management

This category includes vulnerabilities related to memory management, identified across most of the included studies. These vulnerabilities include overflow vulnerabilities, such as buffer and integer overflow, mostly caused by the lack of input sanitization. Moreover, this category includes null pointer dereference and use-after-free memory allocation vulnerabilities. These issues arise due to improper handling of memory references and pose significant risks to system security. Although [33, 35, 36, 47, 64, 81, 83, 90, 95, 103] all identified memory vulnerabilities in code produced by LLMs, Liu et al. [64] placed special importance on memory management vulnerabilities. They performed a systematic empirical assessment of the quality of code generated using ChatGPT, by solving 728 algorithmic problems. Their study highlighted significant issues in memory management within LLM-generated code. Specifically, they found that the majority of vulnerabilities were related to missing null pointer tests, with 91.8% of the total vulnerabilities attributed to the MissingNullTest query. These code snippets failed to check for null after memory allocation, which can lead to critical security vulnerabilities such as CWE-476: Null pointer dereference, also identified in [81, 90, 103].

4.3 File Management

File management vulnerabilities are mostly caused by improper handling of files and directories. These vulnerabilities can lead to unauthorized access, data corruption, or system compromise. The most common file management vulnerabilities include improper path restrictions, unrestricted file uploads, and insecure file permissions. Several studies identified file management vulnerabilities in LLM-generated code [9, 27, 31, 33, 35, 36, 47, 64, 66, 81, 83, 95]. However, He et al. [35] dedicated more focus to these vulnerabilities, finding that LLMs often produce code that does not properly restrict file paths based on user input, potentially allowing unauthorized file access. This vulnerability is marked as CWE-22: Improper Limitation of a Pathname to a Restricted Directory ("Path Traversal") [9, 27, 31, 33, 36, 64, 66, 81, 95].

4.4 Deserialization

Deserialization vulnerabilities happen when untrusted data is used to reconstruct objects within an application, and can lead to arbitrary code execution, data manipulation, or denial-of-service attacks. These vulnerabilities are especially concerning in systems that use serialization for communication or storage, as they can be exploited if proper validation and sanitization are not implemented.

Several studies recognized CWE-502: Deserialization of Untrusted Data [27, 31, 36, 47, 64, 66, 87, 95], however, none of them specifically focused on this topic, leaving some open questions for further research. For example, how frequently do LLMs generate insecure code when prompted with tasks targeting deserialization vulnerabilities?

4.5 Sensitive Data Exposure

Sensitive data exposure occurs when critical information, such as personal data, financial details, or authentication credentials, are not properly protected and become accessible to unauthorized entities. Sensitive data exposure is often caused by ineffective data encryption, insecure storage, or flaws in data transmission protocols. Several studies recognized the exposure of sensitive data in the code generated by LLMs [9, 27, 31, 36, 47, 64, 66, 81, 94]. Jamdade et al. [41] reported sensitive data exposure in code generated by ChatGPT for web-application user-data handling. Moreover, Pearce et al. [81] studied how frequently and why GitHub Copilot generates insecure code by testing it with 89 different scenarios related to high-risk cybersecurity vulnerabilities. Besides finding that approximately 40% of these programs were vulnerable, they showed that Copilot consistently fails when it comes to CWE-200: Exposure of Sensitive Information to an Unauthorized Actor.

Similarly, Aydin et al. [9] found that CWE-200 was the most prevalent weakness in LLM-generated JavaScript across 6 LLMs (127 occurrences, 21% of reported vulnerabilities). The same CWE was also mentioned in [31, 41, 64, 66, 81].

4.6 Authentication and Authorization

Authentication and authorization vulnerabilities represent a significant category of security issues, highlighted in 13 out of 21 studies. **Authentication** vulnerabilities occur when a system fails to properly verify the identity of users or devices. This kind of vulnerability is mostly caused by weak password requirements, insufficiently protected credentials, or the use of hard-coded credentials. Hamer et al. [34] compared the security properties of the code generated by ChatGPT, with answers provided in Stack Overflow. They concluded that ChatGPT-generated code had 20% fewer vulnerabilities than Stack Overflow snippets, although both produced security flaws. One of the most frequent CWES in both ChatGPT-generated code and Stack Overflow snippets was CWE-798: Use of Hard-coded Credentials. CWE-798 is also reported in [24, 27, 31, 34, 64, 81, 94]. In contrast, Majdinasab et al. [66] evaluated Copilot using multiple targeted CWE scenarios. For CWE-798 specifically, they reported zero vulnerable outputs for the corresponding prompts.

Authorization vulnerabilities arise when a system fails to enforce access control policies properly, which allows users or processes to perform actions beyond their intended permissions. This vulnerability is often caused by improper implementation of access control. The associated CWE is CWE-284: Improper Access Control, as discussed by Asare et al. [8], who conducted a comparative empirical analysis of Copilot-generated code, showing that GitHub Copilot is less likely to produce vulnerable code compared to human developers.

4.7 Cryptography

Cryptographic vulnerabilities arise when encryption mechanisms are poorly implemented or completely absent. Common causes include the use of broken or insecure cryptographic algorithms, improper validation of certificates, the use of weak or absent hashing functions, and the reuse or hard-coding of cryptographic keys. Several studies [9, 27, 31, 34, 36, 47, 87, 94, 95] identified cryptographic weaknesses in LLM-generated code without exploring them in detail. Perry et al. [83] studied how users interact with AI code assistants to solve security-related tasks. The study found that participants with access to an AI assistant were more likely to produce incorrect and insecure solutions, compared to a control group. Specifically, in one cryptography-related task, participants with AI assistance were more likely to use trivial ciphers or fail to authenticate the final output.

A common cryptographic vulnerability identified in multiple studies is CWE-327: Use of a Broken or Risky Cryptographic Algorithm [9, 24, 36, 87, 95, 103].

4.8 Resource Management

Resource Management vulnerabilities refer to weaknesses in the handling, allocation, and release of system resources that are not strictly related to memory or file systems. These vulnerabilities were also identified across multiple studies as improper control of resources, resource leaks, and improper resource shutdowns. Hamer et al. [34] identified two prevalent resource management vulnerabilities in ChatGPT-generated code: CWE-404: Improper Resource Shutdown or Release, and CWE-772: Missing Release of Resource after Effective Lifetime. Both CWEs were tied as the second most frequent vulnerabilities, each appearing in 37, out of 216 code snippets. Other studies also highlighted related vulnerabilities, including CWE-605: Multiple Binds to the Same Port [31, 87], and CWE-664: Improper Control of a Resource Through its Lifetime [8].

In general, resource management vulnerabilities in LLM-generated code were identified by [8, 9, 25, 31, 34, 47, 87], however, none of these studies explored them in depth.

4.9 Coding Standards

This vulnerability category includes issues arising when software development practices do not adhere to established standards, leading to inconsistent, unreliable, or insecure code. Such deviations can introduce bugs, security flaws, or system crashes. Common vulnerabilities of this type include logical errors, such as division by zero and incorrect calculations, as well as issues with function calls, such as incorrect number of arguments or incorrect argument types. Tihanyi et al. [103] conducted a comparative analysis of LLMs to examine how likely they are to generate vulnerabilities when writing simple C programs. They identified division by zero as a frequent issue in the code generated by LLMs, along with the challenges in managing arrays and arithmetic operations.

Additionally, CWE-758: Reliance on Undefined, Unspecified, or Implementation-Defined Behavior is another significant concern discussed by Sandoval et al. [90]. Besides the mentioned studies, others focused on this type of vulnerability, but without exploring it in detail, as can be seen in [8, 27, 31, 33, 36, 47, 61, 81, 87, 95, 103, 105].

4.10 Error Handling

Error handling vulnerabilities arise when a system or application fails to properly manage exceptional conditions. Poor error handling can lead to various issues, including security vulnerabilities, system crashes, or unreliable software behavior. One common issue in error handling is the failure to check or handle return values from functions or system calls properly. A few studies focused on error handling vulnerabilities [9, 27, 31, 87, 90], however, none of these studies specifically addressed this category of vulnerabilities, which presents another topic for future research. Among the various CWEs, CWE-703: Improper Check or Handling of Exceptional Conditions has been specifically highlighted in the literature as a notable issue [87].

4.11 LLMs in Code Generation: Balancing Risks and Benefits

As we described throughout this section, LLMs often produce code with security vulnerabilities [27, 83, 94, 103, 105]. Interestingly, when ChatGPT fixes human-written code, the revised version often contains more security vulnerabilities compared to code generated from scratch by ChatGPT [87].

Despite these challenges, LLMs remain valuable tools in coding tasks. Research indicates that code generated by ChatGPT generally introduces fewer CWE issues compared to code found on Stack Overflow [34]. Moreover, LLMs do not significantly increase the incidence rates of severe security bugs [90], and tools like GitHub Copilot have been shown to produce code with fewer security vulnerabilities than code written by human developers [8].

Although LLMs may generate vulnerable code, the literature suggests that using more effective prompts can guide them to produce safer code [47, 64]. Through improved re-prompting, the security issues initially present in LLM-generated code can often be addressed, making LLMs valuable tools for creating secure code when used appropriately. This topic will be explored in more detail in Subsection 7.1. In practice, the evidence in this section points to a more cautious use of LLMs in software development. Developers should assume that suggestions may contain vulnerabilities and review them carefully before integrating the code.

5 LLMs for Vulnerability Detection

While LLMs can introduce vulnerabilities into the code they generate, the same models also offer opportunities to improve software security, particularly through their use in vulnerability detection. Security code reviews performed manually require significant time and effort, especially in large-scale open-source projects with many contributions. Hence, the automated tools able to identify

security vulnerabilities during code review are highly beneficial [80]. Among these tools, LLMs emerged as a promising solution for detecting security vulnerabilities.

In this section, we address the vulnerability detection aspect of RQ2 by exploring how LLMs are used to detect vulnerabilities in code. We first describe the benchmarks and datasets used for evaluation, then summarize the programming languages and the LLMs evaluated in the reviewed studies. We further review how LLMs compare with non-LLM approaches and discuss reported challenges and influencing factors. Finally, we examine the proposed methods for improving effectiveness in this task. Across the works we review in this section, performance is typically reported in terms of F1 score and recall, sometimes complemented by precision and False Positive (FP) rate. However, the primary studies do not report a consistent set of metrics. Some focus only on F1 or accuracy, others use detection and FP rates or the number of vulnerabilities found, and some adopt task-specific scoring schemes. Together with differences in datasets, benchmarks, and task formulations, this makes direct comparisons of reported performance inconclusive.

5.1 Benchmarks and Datasets used for LLM-Based Vulnerability Detection

Before examining how effective LLMs are at detecting vulnerabilities, we first outline the benchmarks and datasets on which they are evaluated, as these choices strongly influence the performance that studies report. As summarized in Table 7 in Appendix A, many studies rely on existing vulnerability datasets and benchmarks such as SARD, NVD, Juliet, Devign, and BigVul. Several papers also curate subsets of these datasets or combine multiple sources into one evaluation set.

In addition to these adapted datasets, other studies introduce new, named benchmarks and datasets specifically designed for evaluating LLM-based vulnerability detection. For instance, Ding et al. [22] introduced the PrimeVul benchmark and demonstrated that performance reported on commonly used benchmarks can be overestimated, leading models to appear more effective than they actually are in more realistic settings. For example, the 7B StarCoder2 model achieved a 68.26% F1 score on the popular BigVul dataset but only 3.09% on PrimeVul. Similarly, Carletti et al. [14] proposed MVFSC, a benchmark of 972 real-world C/C++ functions from production open-source projects, showing that LLMs performance drops substantially when evaluated on real-world codebases. Other works propose additional smaller benchmarks that vary by language/platform and evaluation design [50, 57, 78, 108].

These datasets and benchmarks cover different languages and difficulty levels, and should be taken into account when interpreting reported LLM performance. Recent benchmark proposals further suggest that commonly used benchmarks may make models seem more effective than they are. This should be kept in mind when drawing conclusions about performance in realistic settings.

5.2 Programming Languages and Models used for LLM-Based Vulnerability Detection

Beyond benchmarks and datasets, LLM-based vulnerability detection is also influenced by the programming languages and models used.

Some studies explicitly examine how LLM performance varies across programming languages. For instance, Lin et al. [60] compared vulnerability detection on Java and C/C++ and reported higher performance on Java, with an F1 score of 57.98% on Java compared to 34.71% on C/C++. Khare et al. [45] also reported a similar trend on the Juliet benchmark, where under the same model and prompt setting, the F1 score is 79% on Juliet Java compared to 70% on Juliet C/C++. More broadly, Yu et al. [120] showed that vulnerability detection performance varies substantially across programming languages, highlighting limited cross-language generalization.

Most other studies include one or more programming languages in their datasets but do not report language-specific results. Across the 57 included studies, Figure 4 shows that C (35 studies) and C++ (28 studies) are the most frequently evaluated languages. Java, Python, and PHP appear

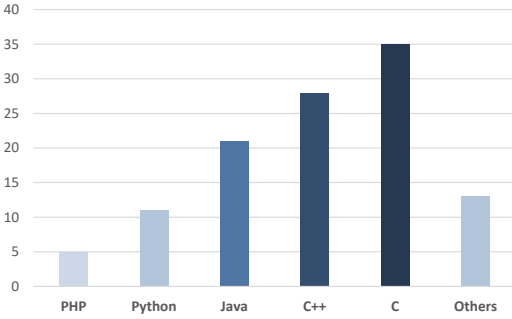


Fig. 4. Distribution of programming languages in LLM-based vulnerability detection studies.

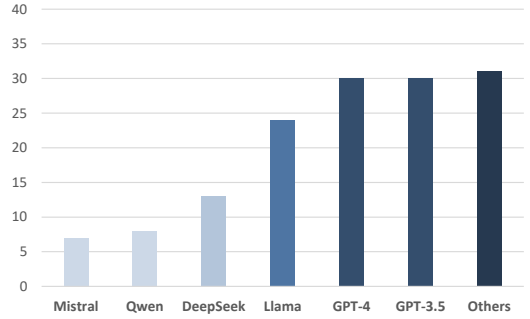


Fig. 5. Distribution of LLM families used in vulnerability detection studies.

less frequently (21, 11, and 5 studies, respectively), while the remaining languages are grouped as "Others". Because most studies evaluate multiple languages, these counts are not mutually exclusive.

Several studies evaluate multiple LLMs side by side [20, 22, 30, 32, 40, 57, 68, 72, 86, 101, 114], whereas many other works treat the model choice as just one experimental factor among others. Figure 5 summarizes the LLM families evaluated in the reviewed studies. GPT-based models dominate the literature, with both GPT-3.5 and GPT-4 appearing in 30 of the 57 studies. Llama is also widely evaluated (24 studies), while DeepSeek, Qwen, and Mistral appear less frequently (13, 8, and 7 studies, respectively). The remaining low-frequency models are grouped as "Others" (31 studies). Because most studies evaluate multiple models, these counts are not mutually exclusive.

In conclusion, language and model choices influence LLM-based vulnerability detection performance. Cross-language comparisons report higher performance on Java than on C/C++, but further investigations are warranted for different languages. Overall, studies focus on C/C++ and mainly use GPT-3.5/GPT-4, with a smaller share considering other programming languages and model families. For further details, we refer the reader to Table 7 in Appendix A

5.3 Comparison of LLMs with non-LLM Vulnerability Detection Approaches

LLMs show promise in vulnerability detection, but it is essential to compare their performance against other approaches, such as SATs and other ML models (including PLMs). Table 4 summarizes non-LLM approaches used as baselines when evaluating LLMs. The upper block lists SATs, while the lower block reports ML-based baselines, including PLMs. The Outcome column reports which approach achieved the best performance as defined in each study evaluation.

In multiple studies, LLM approaches achieve higher vulnerability detection performance than SAT baselines. Wang et al. [111] proposed a pipeline that uses a fine-tuned LLM to detect vulnerabilities and validates suspicious cases with execution-based checks. They reported that their approach outperforms SATs, achieving 95.07% F1 score, compared to 78.36% for the best-performing SAT baseline. Kouliaridis et al. [50] evaluated 9 LLMs against two SATs. Across 100 vulnerable samples, the best-performing SAT flagged 29 security issues, whereas the best LLM (Code Llama) detected 81. Xia et al. [114] reported that task-aware prompting and multi-query self-validation enable GPT-4 to outperform cryptography-focused SATs, improving accuracy over the best SAT baseline by 26.7%. Chen et al. [16] reported that their proposed pipeline, VulKILLER, achieved better results than SAT baselines, including substantially lower FP rates.

Some studies reported a trade-off such that higher vulnerability detection comes at the cost of higher FP rates. Purba et al. [85] reported higher detection by LLMs, but with FP rates exceeding 60%, compared to rates under 45% for SATs. Ozturk et al. [78] reported that ChatGPT identified

Table 4. Non-LLM baselines used to evaluate LLM-based vulnerability detection. Outcome indicates the best-performing approach reported per study, where LLM+SAT denotes a pipeline combining an LLM with a SAT, and LLM/PLM (or LLM/ML) denotes similar performance.

Reference	Baselines	Outcome
Static analysis tools (SATs)		
Ozturk et al. [78]*	BetterScan CE, OWASP WAP, PHPcs, Pixy, Progpilot, Psalm, RATS, RIPS, SonarQube, VCG, Horusec	LLM
Tamberg et al. [98]*	CodeQL, SpotBugs	LLM
Purba et al. [85]*	Checkmarx, Flawfinder, RATS	LLM
Gneciak et al. [30]*	SonarQube, CodeQL, SnykCode	LLM
Wang et al. [111]	Fortify, SpotBugs	LLM
Kouliaridis et al. [50]	Bearer, MobSFscan	LLM
Xia et al. [114]	CryptoGuard, CogniCryptSAST, SpotBugs	LLM
Chen et al. [16]	Fortify, SpotBugs	LLM
Li et al. [58]	CodeQL	LLM+SAT
Li et al. [54]	UBITect	LLM+SAT
Mohajer et al. [71]	Infer	LLM+SAT
Bakhshandeh et al. [11]	Bandit, Semgrep, SonarQube	LLM+SAT
Xu et al. [115]	Joern	LLM+SAT
Munson et al. [72]	Semgrep	LLM+SAT
Machine Learning (ML)-based models		
Chen et al. [17]†	Flawfinder, VulDeePecker, SySeVR, SlicedLocator	LLM
Khare et al. [45]†	CodeQL, DeepDFA, LineVul	LLM
Wen et al. [112]	Devign, ReVeal	LLM
Zhang et al. [121]	Bugram, CFGNN	LLM
Jiao et al. [42]	CFGNN, VulACLLM	LLM
Zhu et al. [131]	BiLSTM, AST+GAT	LLM
Li et al. [56]	VulDeePecker, SySeVR, Devign, ReVeal, AMPLE, CasualVul	LLM
Liu et al. [63]	SySeVR, VulDeePecker	LLM
Liu et al. [65]	SySeVR, VulDeePecker	LLM
Li et al. [55]	VulDeePecker, SySeVR, Devign, ReVeal, CasualVul	LLM
Tian et al. [101]	LineVul, UnixCoder, LineVD	LLM
Mao et al. [68]	LineVul, CausalVul, CodeBERT, CodeT5	LLM
Qiu et al. [86]	Devign, ReVeal, MGVD, UniXcoder, CodeT5, LineVul	LLM
Rafiq et al. [88]	LR, Multinomial Naïve Bayes, Linear SVC	LLM
Maligazhdarova et al. [67]	LR, KNN, Bernoulli Naïve Bayes, Decision Tree, RF, MLP, CNN	LLM/ML
Zhang et al. [124]	VulTeller, Transformer, CodeBERT, GraphCodeBERT, PLBART, CodeT5	ML
Ni et al. [74]	Devign, ReVeal, IVDetect, LineVul, SVulD	ML
Thapa et al. [100]	BiLSTM, BiGRU, BERT, MegatronBERT, DistilBERT, CodeBERT	LLM/PLM
Zhou et al. [129]	CodeBERT	LLM
Shestov et al. [93]	ContraBERT	LLM
Guo et al. [32]	CodeBERT, VulBERTa-MLP variants	LLM
Yu et al. [120]	UniXcoder, CodeBERT, CodeT5, CodeT5P, LineVul	PLM
Zhang et al. [126]	UniXcoder, CodeBERT	PLM
Curto et al. [20]	CodeBERT, PolyCoder, NatGen	LLM/PLM

Note: Studies marked with * showed that LLMs detected more vulnerabilities than SATs, but produced a higher FP rate. Studies marked with † use both SATs and ML-based approaches as baselines.

62-68% of vulnerabilities, while the best-performing SAT detected 32%, with FP rates of 91% for ChatGPT and up to 82% for SATs. Gneciak et al. [30] reported that LLMs performed better overall but exhibited approximately 34–65% FP, while SATs were generally under 25%. Tamberg et al. [98] reached similar conclusions, adding that adaptability and contextual understanding still make LLMs effective for vulnerability detection. We discuss FP in more detail in Subsection 5.4.

Several studies explored pipelines where LLMs and SATs complement each other to improve vulnerability detection. Li et al. [58] proposed IRIS, a framework that uses an LLM to generate CodeQL taint specifications, runs CodeQL to find vulnerability reports (taint flows), and then uses an LLM to review those reports to filter FP. Compared to using CodeQL alone, IRIS increased detected vulnerabilities by 35% and reduced FP by 80%. Li et al. [54] introduced LLift, which runs UBITect with symbolic execution and applies an LLM to undecided cases, improving accuracy and uncovering 4 UBI bugs in the Linux kernel that UBITect alone could not confirm. Xu et al. proposed VulPelican, where LLM queries the SAT for cross-file data flows and function dependencies. The retrieved information is fed back to the LLM, which refines its analysis over multiple rounds.

Some studies use LLMs on top of SAT outputs to confirm reported bugs and discover additional ones. Mohajer et al. [71] applied Infer to detect potential vulnerabilities and then used ChatGPT to re-evaluate the reported warnings. ChatGPT achieved high precision in filtering FP. Bakhshandeh et al. [11] found that ChatGPT alone did not outperform SATs, but using it to re-check SAT findings improved F1. Munson et al. [72] prompted an LLM with code and Semgrep reports to determine whether each reported issue is a true vulnerability or an FP. Semgrep achieved 74.15% F1, while Semgrep+o1-mini improved this to 86.92%.

Beyond SATs, researchers also compare LLMs against ML-based baselines, mainly specialized learning-based vulnerability detectors, to assess the effectiveness of LLMs in detecting vulnerabilities. Jiao et al. [42] proposed an LLM-based vulnerability detection framework, and reported that it outperformed ML baselines, achieving up to 75.3% accuracy compared to 52.0% for the best-performing ML baseline. Chen et al. [17] reported that their LLM-based framework outperforms all SAT and ML baselines, achieving an F1 score of 92.73%, compared to 89.53% for the best-performing baseline. Zhu et al. [131] fine-tuned Qwen2-7B and achieved 91.44% average accuracy, surpassing the BiLSTM baseline (83.39%). Khare et al. [45] evaluated 16 LLMs for vulnerability detection and reported that their best LLM-based configuration outperforms the non-LLM baselines in the main F1-based comparisons, reaching 65% F1. Additional studies report that LLM-based vulnerability detection outperforms ML-based baselines in their evaluations [55, 56, 63, 65, 86, 101, 112, 121]. In contrast, some studies report that specialized ML-based vulnerability detectors achieve higher overall performance than LLMs on the benchmarks they evaluate [74, 124].

Beyond specialized ML detectors, Rafiqe et al. [88] compared fine-tuned LLMs with classical ML classifiers (Logistic Regression, Multinomial Naïve Bayes, and Linear SVC), finding that fine-tuned LLMs achieved higher test accuracy (up to $\approx 84\%$) than the strongest ML baseline ($\approx 78\%$). Maligazhdarova et al. [67] reported task-specific results for injection vulnerability detection, when comparing a fine-tuned GPT-4o-mini against multiple classical ML classifiers. For SQL injection, Random Forest achieved 99% accuracy, whereas for NoSQL injection, a fine-tuned GPT-4o-mini reached 97% accuracy and outperformed all ML baselines.

Thapa et al. [100] evaluated several Transformer-based language models, including both LLMs and PLMs, and found that both model families achieve comparable performance overall and outperform non-Transformer ML baselines. Several other studies use PLMs, mostly from the BERT family, as baselines when evaluating LLMs for vulnerability detection [32, 68, 86, 93, 101, 129]. Overall, these works show that properly tuned or carefully prompted LLMs often outperform these PLM baselines.

However, some studies report that PLM-based detectors outperform LLMs. Yu et al. [120] reported an F1 score of 70.75% for CodeT5P, while the best-performing LLM, QwQ-plus, reached 51.11%.

Ullah et al. [108]			×	
Purba et al. [85]	×			
Ding et al. [22]			×	
Çetin et al. [15]	×			
Zhang et al. [124]				×
Li et al. [53]	×			
Tamberg et al. [98]	×			
Wang et al. [111]	×			×
Jiao et al. [42]	×			
Kouliaridis et al. [50]		×		
Carletti et al. [14]	×		×	
Zhang et al. [126]	×			×
Xu et al. [115]		×	×	×
Chen et al. [17]		×		
Li et al. [57]	×		×	
Xia et al. [114]	×	×	×	×
Gneciak et al. [30]	×			
Li et al. [56]			×	
Chen et al. [16]	×			
Mao et al. [68]			×	
Zhou et al. [130]	×			
	False Positives	Missing Context	Complex Scenarios	Token Limits

Fig. 6. Matrix visualization mapping reported challenges (columns) to reviewed studies (rows) for LLM-based vulnerability detection. A cross (×) denotes that a study reports the corresponding challenge.

Zhang et al. [126] similarly reported that, in their evaluation, the best-performing LLM achieved 58.35% F1, while MAGNET achieved 66.12% F1. The authors suggested that this is likely because LLMs are mainly pre-trained for code generation, not for learning vulnerability patterns. Curto et al. [20] reported mixed results. Fine-tuned Llama 3 and Code Llama performed better for detecting vulnerable functions, but CodeBERT was better at pinpointing the vulnerable lines.

In summary, many studies report that LLMs match or outperform SATs for vulnerability detection, but often at the cost of higher FP. However, combining LLMs with SATs frequently improves detection. Comparisons against ML-based baselines and PLM baselines show mixed results, and the best-performing approach varies across studies and evaluation settings.

5.4 Challenges in Using LLMs for Vulnerability Detection

While LLMs show considerable promise for vulnerability detection, several challenges remain. In this section, we aim to unwrap the challenges reported in the literature. Figure 6 presents a mapping between the reviewed studies (rows) and the reported challenges (columns). A cross (×) indicates that the corresponding study reported the given challenge. Most studies report FP rates or performance with complex scenarios, while the other two challenges appear less frequently.

FP represent a key challenge for LLMs, where the model incorrectly flags non-existent vulnerabilities. Some studies report that, while LLMs outperform SATs in vulnerability detection, they also produce higher FP rates [30, 78, 85, 98]. Çetin et al. [15] found that GPT-4 exhibited an FP rate of 63%, with other models reaching up to 97%. High FP rates are also reported in other works [14, 57]. Several studies propose techniques to mitigate FP when using LLMs as vulnerability detectors [16, 42, 53, 111, 114, 126, 130].

Kouliaridis et al. [50] observed that LLM-based vulnerability detection is often limited by **missing context**. Missing context refers to cases where the prompt lacks essential information needed to judge whether code is vulnerable. Xu et al. [115] showed that LLM-only analysis can miss vulnerabilities when relevant information spans multiple files (e.g., call chains, data flows, dependencies) and is omitted from the prompt. Chen et al. [17] reported similar failures when key code details (e.g., variable values or size information) are missing. Xia et al. [114] further found that limited class-level context can cause LLMs to miss cryptographic misuses that require multi-hop reasoning.

Beyond missing context, LLMs also struggle in **complex scenarios**, where the relevant information may be available but is harder to use effectively. Li et al. [57] found degraded performance in scenarios that require flow-aware (control/data-flow) reasoning. Xu et al. [115] argue that vulnerabilities often involve cross-function call chains and dependencies, making single-function LLM-only detection unreliable. Xia et al. [114] observed similar performance drops on cryptographic misuses requiring inter-procedural, multi-hop call-chain reasoning.

These complexity-related challenges become more pronounced in real-world settings. Carletti et al. [14] showed that even after fine-tuning, performance drops substantially on real-world codebases not seen during training. Li et al. [56] further observed a localization challenge in real-world programs, where vulnerable segments may constitute only a small portion of a function, making them harder for LLMs to detect. Overall, several studies agree that current LLM-based approaches still fall short for vulnerability detection in complex, real-world scenarios [22, 68, 108].

Token limitations constrain how much code and context can be provided to an LLM during vulnerability detection. Xu et al. [115] identified this challenge when prompting LLMs with SAT outputs. Similarly, Xia et al. [114] found that performance degrades on longer inputs, sometimes yielding low-quality or even empty outputs near the context limit. Related work reports similar issues and proposes mitigation strategies [111, 124, 126].

The literature highlights several recurring challenges when using LLMs for vulnerability detection. Some of the reviewed works propose techniques to address these challenges [16, 42, 53, 111, 124, 126, 130], which we discuss in more detail in Subsection 5.6. Despite the challenges we highlighted, most of the studies agree that LLMs can be effective tools for vulnerability detection.

5.5 Factors Influencing LLMs Performance

Despite the remarkable capabilities of LLMs in vulnerability detection tasks, their effectiveness is influenced by various factors, including the prompts used (further explored in Section 8) and the state of the code being analyzed.

Yu et al. [120] reported that detection performance varies across programming languages, indicating that the language of the analyzed code is an important factor for vulnerability detection. Jiao et al. [42] found that detection outcomes are impacted by code length. In their analysis, Llama models produced more FP on longer code, while DeepSeek models showed the opposite tendency. Consistent with this, Lin et al. [59] observed that some models degrade as input length increases, and Zhou et al. [129] similarly reported degraded accuracy and increased FP for inputs longer than 3000 characters. Beyond length, Sovrano et al. [96] showed that performance is sensitive to the position of the vulnerable code within the input. Even when an entire file fits within the model context window, LLMs are more likely to miss vulnerabilities located toward the end of large files.

Taken together, these studies show that LLM-based vulnerability detection is highly sensitive to factors beyond the model itself, including programming language, code length, and the position of the vulnerability within the input. These factors should be considered when using LLMs for vulnerability detection in practice.

5.6 Improving LLM-Based Vulnerability Detection

In light of the limitations and influencing factors we discussed in the previous subsections, many studies explored different ways to enhance LLMs ability to detect vulnerabilities.

One direction for improving LLM-based vulnerability detection is to **pre-process the code** before feeding it to the model to enrich the input. Thapa et al. [100] translated code into vectorized inputs for vulnerability analysis, where GPT-2 Large achieved 95.51% F1. Wen et al. [112] proposed SCALE, which builds an AST and augments nodes with short auto-generated comments, reaching around 65% F1. Anbiya et al. [6] evaluated AST, CPG, and combined AST+CPG representations and concluded that CPG-only inputs were most effective overall.

Other works address long inputs and token limits by splitting code into smaller units while trying to preserve semantics. Zhang et al. [124] used overlapping sliding windows with a right-forward embedding strategy to enrich context. Wang et al. [111] used CFG-based semantic segmentation and CFG sub-paths to mitigate token limitations, and applied targeted execution checks to reduce FP. Zhang et al. [126] decomposed long functions into AST sub-trees and enriched them with LLM-generated comments. Sovrano et al. [96] improved file-level detection by chunking large files and reported over 37% average recall improvement, while noting that reduced global context may increase FP. Saimbhi et al. [89] applied function-level segmentation to PHP snippets and prompted an LLM per function for detection and CWE labeling, reporting zero FP but only 68% recall.

Beyond input-level pre-processing, some studies focus on reducing FP by using LLMs in a multi-step filtering and validation process that checks vulnerability candidates produced by SATs or an initial LLM pass. Li et al. [53] used ChatGPT to summarize and refine static-analysis warnings, helping developers prioritize issues and eliminating most FP in their experiments. Jiao et al. [42] similarly targeted FP reduction with their multi-round LLM-based vulnerability detection framework, DeepVulHunter. Chen et al. [16] combined Code Property Graph (CPG)-based structural and data/control-flow analysis with LLM-generated Proof-of-Concept exploit inputs (PoCs) and run-time validation to confirm vulnerabilities, reducing the FP rate to 4.3%. Zhou et al. [130] combined PHPJoern-based CPG taint analysis with an LLM to validate Server-Side Request Forgery (SSRF) candidates by checking user control over URL components (e.g., host/authority and path) and path feasibility, reducing 12 taint paths to 7 confirmed vulnerabilities.

Other studies focus on improving the models to enhance vulnerability detection. Li et al. [56] proposed an inference-time activation steering approach. They computed a "vulnerability steering vector" from representation differences between paired vulnerable and patched functions, and injected it into selected transformer layers during inference to bias the model toward vulnerability-related semantics. With this approach, their steered LLMs outperformed ML-based vulnerability detectors, achieving an F1 score of up to 96.25%.

Several researchers explored **fine-tuning** to improve vulnerability detection. As illustrated in Figure 7, fine-tuning adapts a pre-trained model to a security task by further training on a security-specific dataset. Guo et al. [32] reported that a fine-tuned CodeLlama-7B achieved 97% F1 on their dataset, while the best-performing model without fine-tuning achieved about 51% F1. Mechri et al. [69] fine-tuned Qwen and enabled long-context analysis of larger codebases, achieving F1 scores ranging from 84% to 99%. Curto et al. [20] fine-tuned Llama 3 and Code Llama for vulnerability detection, achieving up to 95.3% F1 for function-level detection and up to 69.63% Top-10 accuracy for line-level localization on BigVul. Ibanez-Lissen et al. [39] fine-tuned Gemma-2B for multi-class CWE detection, achieving 95.9% F1 for binary vulnerability detection. Zhu et al. [131] fine-tuned Qwen2-7B for CWE-level Java vulnerability detection and reported strong performance on their curated dataset. Shestov et al. [93] fine-tuned WizardCoder for vulnerability detection and reported an F1 score of 71%. Wang et al. [111] similarly reported gains from fine-tuning over the base model.

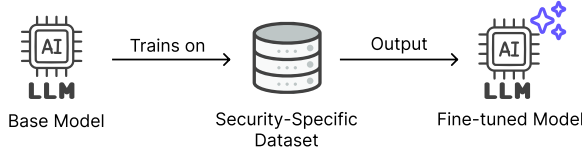


Fig. 7. Fine-tuning an LLM on the security-specific dataset.

Beyond standard fine-tuning, Zhang et al. [124] compared two fine-tuning setups for vulnerability localization, a classification approach that labels each line or statement as vulnerable or not, and a generative approach that predicts vulnerable line numbers and statements. The authors found the classification setup stronger, reporting an F1 score of 82.0% with CodeLlama-7B, compared to 44.8% for the generative setup. Moreover, Mao et al. [68] extended fine-tuning by proposing a framework named LLMVulExp, which uses a teacher LLM to generate training explanations for each code sample and fine-tunes a student model to perform vulnerability detection and produce natural-language explanations. In their evaluation, LLMVulExp achieved an F1 score of up to 98.8%.

Li et al. [55] proposed VulnTeam, which extends single-model fine-tuning with role-specialized tuning and aggregation. They fine-tune 5 LLM “experts” on different vulnerability-feature categories and instruction-tune a lightweight “leader” model to combine the experts’ analyses into the final decision. VulnTeam outperformed single-model fine-tuning baselines, achieving up to 96.02% F1.

Despite these improvements, Guo et al. [32] cautioned that gains are largely limited to the training tasks, and that labeling errors in current datasets can compromise training and performance. Ding et al. [22] reported that fine-tuning StarCoder2-7B improves F1 from 3.09% to 18.05%, but the models still miss many vulnerabilities. Carletti et al. [14] further showed that even after fine-tuning CodeLlama-7B, performance drops substantially on MVFSC, a real-world test set from open-source projects not seen during training. Some papers also include fine-tuning [6, 20, 67, 85, 88, 100]. However, in these works, fine-tuning is typically used as part of a broader empirical evaluation or system setup (often for only a subset of the evaluated models), rather than being the primary focus.

In conclusion, pre-processing code, combining LLMs with SATs, and adapting models through fine-tuning all raise vulnerability detection scores on the reported benchmarks. At the same time, prior work notes that these gains are largely limited to the tasks and datasets used for training and evaluation, and that even fine-tuned models still miss many vulnerabilities.

6 LLMs for Vulnerability Fixing

Developers often introduce security vulnerabilities in their code, which, if exploited, can compromise system and application security. While prior work has shown that LLMs can be effective at detecting vulnerabilities, their capabilities do not end there. Beyond identifying vulnerabilities, LLMs can assist in providing the right fixes, significantly reducing developers’ workloads [82]. In this section, we address the vulnerability fixing aspect of RQ2 by exploring the use of LLMs for fixing vulnerabilities. We first summarize the datasets, programming languages, and models. Then, we discuss challenges LLMs encounter when fixing vulnerabilities and fine-tuning approaches proposed to address them.

6.1 Programming Languages, Models, and Datasets for LLM-Based Vulnerability Fixing

Before delving into the reviewed studies, it is worth noting that the literature evaluates LLM-based vulnerability fixing under different experimental setups. The models, programming languages, and datasets used in each vulnerability fixing study are listed in detail in Appendix A (Table 8).

Overall, most vulnerability fixing evaluations focus on C and C++, with fewer studies considering Java and other higher-level languages. Although C and C++ dominate existing evaluations,

Wang et al. [109] performed a cross-language comparison and showed that these languages yield the lowest vulnerability fixing success rates, suggesting that generating correct fixes is more difficult for C/C++ than for other languages such as Go, which achieved the strongest performance.

Across the reviewed vulnerability fixing studies, GPT-family models are analyzed most frequently, while families such as Claude, Codex, LLaMA, and Mistral appear less frequently. Some studies also compare models side by side. For instance, Braconaro et al. [13] evaluated GPT-4o, Gemini 1.5 Flash, and Gemini in Android Studio for vulnerability fixing, reporting 93.8% accuracy for GPT-4o, compared to 83.8% and 83.5% for the two Gemini models, respectively. Similarly, Le et al. [52] compared ChatGPT and Bard, reporting repair accuracies of 71.66% and 68.33%, respectively.

Evaluation of vulnerability fixing relies on a mix of real-world CVE-based benchmarks and curated datasets, most commonly ExtractFix, CVEFixes, Big-Vul, and Vul4J, alongside manually constructed evaluation sets. Braconaro et al. [13] proposed a dataset of 272 security best-practice violations paired with ground-truth repairs. Similarly, de-Fitero-Domínguez et al. [21] constructed a refined repair dataset by removing train-test overlap to support more reliable evaluation.

Overall, the vulnerability fixing literature remains centered on GPT-family models and C/C++ code, with fewer studies covering other model families and programming languages. LLM-based vulnerability fixing performance is also evaluated on a diverse set of benchmarks and datasets, which further limits direct comparisons across reported results.

6.2 Challenges in Using LLMs for Vulnerability Fixing

The literature on LLM-based vulnerability fixing also identifies several challenges that affect the reliability and effectiveness of generated repairs.

A key challenge in LLM-based vulnerability fixing is handling **context-sensitive, non-local repairs**. Zhang et al. [125] show that LLMs are effective at fixing localized memory-related issues in C/C++ code, but struggle when repairs depend on external functions, data structures, or complex program logic. However, providing additional contextual information can improve fixing performance. Pearce et al. [82] similarly report that, while LLMs can fix synthetic and hand-crafted vulnerabilities, performance degrades on real-world code in zero-shot settings due to insufficient context and high sensitivity to prompt formulation and natural language variations. Wang et al. [110] concluded that their proposed approach can still fail when the correct fix depends on variables, constants, or function names not present in the available code context. Liu et al. [61] reported similar context-related failures in vulnerability fixing, where missing details can lead ChatGPT to infer or guess information (e.g., a required variable), resulting in an incorrect patch.

A further challenge is the **reliability** of generated fixes, including their **consistency** across repeated runs. Existing studies reported non-deterministic outcomes across repeated runs and hallucinated or unsupported fixes that introduce elements not present in the provided code or context [7, 13]. Tihanyi et al. [104] observed repairs that appear correct but fail to resolve the vulnerability, such as trivial bound adjustments (e.g., adding +1 to an upper bound).

Another major challenge is that generated fixes may be **incomplete**, even when they appear reasonable. Tao et al. [99] note that fix suggestions can miss edge cases or overlook security implications, resulting in partial fixes. Similarly, Tihanyi et al. [104] report that repair difficulty varies across vulnerability types, indicating that some classes of issues are harder to fix than others. Moreover, Firouzi et al. [24] concluded that LLM-based vulnerability fixing is currently most reliable when integrated into a human-in-the-loop workflow. Security improvements often require targeted feedback and manual line-by-line validation rather than one-shot repair prompts.

In summary, the literature highlights that LLM-based vulnerability fixing is sensitive to context and prompt formulation. It is further limited by inconsistent outputs and the risk of incomplete repairs, and reliable security fixes still depend on careful human verification.

6.3 Improving LLM-Based Vulnerability Fixing

Given the aforementioned challenges encountered by LLMs in generating reliable, consistent, and complete fixes, several studies have explored various strategies to improve their performance.

A common approach is fine-tuning LLMs, a process described earlier in Section 5. For instance, de-Fitero-Dominguez et al. [21] fine-tuned Code Llama and Mistral for vulnerability fixing and report that the fine-tuned models achieve up to 23% and 26% Perfect Prediction, respectively, on a refined evaluation set without training–test overlap. Moreover, Wu et al. [113] evaluated LLMs for fixing Java vulnerabilities on two proposed benchmarks, comparing off-the-shelf and fine-tuned variants. Codex fixed 20.4% of the vulnerabilities without fine-tuning, while the best fine-tuned model, InCoder, fixed 18%, which corresponds to an 8% relative improvement over its non-fine-tuned version and was largely limited to simple edits rather than complex CWEs. Finally, Wang et al. [109] investigated fine-tuning for multilingual vulnerability fixing and reported that GPT-4o increased from 26.89% EM to 28.71% EM after fine-tuning.

Another approach improves LLM-based vulnerability fixing without changing the model. Instead, it relies on pre-processing code into structured inputs. Wang et al. [110] propose SPVR, which parses code into an AST and uses simple, rule-based signals to generate targeted prompts and a simplified code snippet for the LLM. With this approach, GPT-4 repair success increased from 65/547 to 143/547 vulnerabilities (pass@3), and CodeBLEU improved from 30.25% to 41.09%.

A different strategy focuses on combining context reduction with LLM-based validation. Nong et al. [76] proposed APPATCH, which reduces the input code by extracting only the parts that influence the vulnerable line. It then prompts the LLM to explain the cause of the vulnerability and generate multiple patch candidates. Finally, APPATCH uses other LLMs to review the candidates and keeps only patches that appear to both fix the vulnerability and avoid breaking program behavior. On ExtractFix APPATCH reached 90% recall and 68.41% F1 score.

Several fixing pipelines augment LLM-based patch generation with external non-LLM feedback (e.g., compiler/tests, verifier counterexamples) to improve reliability and enable iterative refinement of generated patches [51, 104]. In this direction, Kim et al. [48] proposed SAN2PATCH, which uses crash logs from AddressSanitizer and UBSan to guide localization and patch generation, and validates candidate patches through an automated build-and-test loop.

These studies indicate that fine-tuning, code pre-processing and external patch validation can improve vulnerability fixing. However, overall the gains are often small, and the benefits are mostly limited to simple, localized fixes.

7 LLMs for Detecting and Fixing Vulnerabilities in a Unified Process

In Section 5 and Section 6, we discussed using LLMs as tools for handling vulnerability detection and vulnerability fixing separately. In this section, we explore an integrated approach in which LLMs detect and fix security vulnerabilities in a unified process, including identifying vulnerabilities in code they generate themselves and resolving them through re-prompting. Last, we cover fine-tuning for enhancing LLMs performance in a unified pipeline for vulnerability detection and fixing. The models, programming languages, and datasets used in the reviewed studies that combine vulnerability detection and fixing are summarized in Appendix A, Table 9. Some studies discussed in this section are instead listed in Appendix A, Table 6, as they also address RQ1.

7.1 LLMs for Detecting and Fixing Vulnerabilities in Self-produced Code

As we discussed in Section 4, code generated by LLMs may contain security vulnerabilities. However, several studies show that it is possible to re-prompt LLMs to identify and fix those vulnerabilities.

Table 5. Prompt engineering techniques used in the studies for vulnerability detection and fixing.

Technique	References
Zero-shot	[82], [71], [108], [98], [124], [61], [127], [74], [62], [120], [50], [14], [115], [17], [72], [57], [114], [40], [109], [7], [13], [24], [26], [76], [59], [63], [107], [45], [38], [86]
Few-shot	[71], [108], [98], [22], [124], [127], [61], [14], [17], [96], [109], [26], [76], [63], [88], [107]
In-context	[124], [58], [74], [62], [52], [42], [17], [57], [7], [110], [44], [76], [48], [16], [65], [63], [88], [45], [86]
Chain-of-Thought	[121], [71], [82], [108], [98], [124], [127], [74], [62], [42], [14], [17], [72], [40], [99], [76], [48], [68], [65], [88], [107], [38], [101], [130], [86]
Task-oriented	[108], [129], [10], [111], [114]
Role-oriented	[108], [129], [15], [124], [118], [71], [35], [32], [74], [121], [61], [112], [111], [126], [114], [30], [109], [59], [88], [55]

Liu et al. [64] demonstrated promising results in fixing security vulnerabilities using ChatGPT, with over 89% of vulnerabilities successfully mitigated during a multi-round fixing process. In this approach, Liu et al. interacted with ChatGPT over several rounds, providing feedback on the generated code and asking for improvements. Similarly, Gong et al. [31] showed that LLMs often produce vulnerable code, with 75% of the tested code classified as insecure. They further found that advanced LLMs can fix up to 60% of insecure code from other LLMs, but perform poorly on their own code, a phenomenon named *self-repair blind spots*. To address this, the authors developed a tool that uses LLMs in an iterative fix process supported by semantic analysis, improving the security of LLM-generated code. Finally, Khoury et al. [47] instructed ChatGPT to generate programs targeting certain vulnerabilities, then analyzed the code for evident vulnerabilities. If present, they re-prompted ChatGPT to identify them and produce a safer version. The study showed ChatGPT could fix several vulnerabilities when re-prompted, but still required significant human guidance.

Overall, multi-round re-prompting can mitigate many vulnerabilities, but LLMs still struggle with *self-repair blind spots* and typically require human guidance or additional analysis.

7.2 Fine-tuning for Vulnerability Detection and Fixing

To improve vulnerability detection and fixing as a unified process, fine-tuning can be applied to adapt LLMs to security-relevant tasks, following the process described earlier in Section 5.

Zhang et al. [127] fine-tuned LLMs for GitHub Actions workflow tasks and evaluated defect detection and repair, where defects include both syntactic errors and security issues such as code injection vulnerabilities. Focusing on vulnerability detection and fixing, they found that fine-tuning improved the detection of code injection vulnerabilities, achieving up to 98.82% F1 with fine-tuned GPT-3.5, but reported that LLMs were not effective at fixing code injection vulnerabilities.

Fine-tuning can make LLMs highly effective at detecting vulnerabilities, but it does not reliably fix them, so outputs should be carefully reviewed before deployment.

8 Prompting strategies for detecting and fixing vulnerabilities

While LLMs show promise in detecting and fixing vulnerabilities, their effectiveness is not solely determined by model architecture or fine-tuning, it also depends on prompt design. Well-crafted prompts can guide LLMs towards more accurate solutions, while incomplete or ambiguous prompts may result in ineffective solutions [124]. In this section, we address RQ2.1 by exploring the impact of various prompting techniques on the detection and fixing performance of LLMs. Table 5 summarizes the different prompting techniques and corresponding studies.

Analyze the following code for vulnerabilities:
`<code>`

Fig. 8. Example of a prompt, using the zero-shot prompting technique. In green, the main body of the instructions. In blue, the code to be analyzed.

You are a cybersecurity specialist. Analyze the following code for vulnerabilities: `<code>`

Fig. 9. Example of a prompt, using the role-oriented prompting technique. In green, the role assigned to the LLM. In blue, the code to be analyzed.

8.1 Zero-shot Prompting

Zero-shot prompting is a prompting technique in which a model is asked to perform a task using only an instruction or general guideline, without any task-specific examples in the prompt [49]. We provide an example of zero-shot prompting in Figure 8, demonstrating how the user provides instructions without examples. Zero-shot prompting has been explored by most of the studies covered in the remainder of the section. Although effective in some scenarios, zero-shot prompting was generally outperformed by other approaches and used only as a baseline for comparison.

8.2 Few-shot Prompting

While zero-shot prompting involves providing a model with only a general instruction or task description, few-shot prompting is a technique where the model is typically given a few task-specific examples [49], with n -shot prompting referring to cases that use a specific number n of examples. An example of a prompt using the few-shot technique is shown in Figure 12, where a set of task-specific examples is provided to the model, as part of the input.

Ullah et al. [108] observed that few-shot prompting performs consistently better than zero-shot prompting for detecting vulnerabilities in code. The intuition behind these results is that providing explicit examples before performing a task can help the model recognize relevant patterns.

Wang et al. [109] showed that zero-shot prompting is ineffective for vulnerability fixing, while few-shot prompting with a small number of examples substantially improves fixing performance. However, Fu et al. [26] reported that even with demonstration-based prompts, ChatGPT produced 0% correct repair patches, while fine-tuned baselines achieved 7-30%.

It is worth noting that other studies explored few-shot prompting [14, 17, 22, 61, 63, 71, 74, 76, 88, 96, 98, 107, 124, 127]. However, as we discuss in the following subsections, they did not achieve the same level of success and were deemed more promising prompting techniques.

8.3 In-context Prompting

In-context prompting involves including relevant information directly to the prompt to guide the model responses. The idea is to “set the context” for the model, helping it generate more accurate, context-aware responses. Figure 10 illustrates this idea by showing how the user provides contextual information concerning the type of vulnerabilities that the LLM should focus on.

One way to use in-context prompting is to inject repository-level context. Qiu et al. [86] proposed RLV, a repository-aware in-context prompting framework. RLV extracts and injects project context, such as data type definitions and caller information, using static indexing tools, and uses the LLM to summarize and filter the retrieved context before classification. RLV improves cross-project generalization, achieving an F1-score of 31.53% on the unseen-project DiverseVul setting.

Beyond repository-level context, example-based in-context prompting can improve vulnerability detection by providing the model with relevant examples. Ni et al. [74] explored strategies for selecting in-context examples, such as prioritizing high-priority vulnerability types or sampling randomly. They found that prompts using carefully selected examples consistently outperform

Analyze the following code for vulnerabilities, specifically looking for:

- Command injection (where user input could execute unintended commands).
- Arbitrary file access (where users can access or modify files outside expected directories).

`<code>`

Fig. 10. Example of a prompt, using the in-context prompting technique. In green, the main body of the instructions. In blue, the code to be analyzed.

Analyze the following code for vulnerabilities and perform these tasks:

- List found vulnerabilities with a brief description.
- If none found, confirm that the code appears secure.
- Ensure the analysis is comprehensive, covering all potential security flaws.

`<code>`

Fig. 11. Example of a prompt, using the task-oriented prompting technique. In green, the main body of the instructions. In blue, the code to be analyzed.

those using randomly selected ones. Similarly, Liu et al. [63] showed that detection improves when prompts include code-specific context, particularly similar code retrieved from the training set and LLM-generated analysis of the target function, compared to plain zero-shot or few-shot prompting. They extended this approach in [65] by including data-flow graphs alongside the retrieved similar code, improving accuracy from 51.6% to 54.1%, and further to 61.9% when combined with CoT.

Context-rich prompts can also improve end-to-end detect-and-fix performance. Le et al. [52] found that increasing contextual information improves detect-and-fix accuracy, reaching 71.66% for ChatGPT and 68.33% for Bard, with gains of up to 55% over context-free prompts.

In-context prompting is also used specifically for vulnerability fixing. Liu et al. [62] designed four prompting templates for code fixing with increasing amounts of context, ranging from a simple zero-shot prompt to templates that included vulnerability descriptions, vulnerable code snippets, and repair instructions. The template that included parts of the vulnerable code achieved the best results, and an iterative workflow that revised previous outputs further improved fixing accuracy.

Enriching repair prompts with vulnerability semantics can provide additional gains. Antal et al. [7] found that including CVE/CWE descriptions slightly improves vulnerability fixing, increasing the number of distinct vulnerabilities fixed across repeated runs from 18 to 19. Tihanyi et al. [104] used counterexamples produced by a bounded model checker (ESBMC) [28] as in-context information and reported 80 to 90% repair accuracy compared to 31 to 37% without ESBMC feedback. Khan et al. [44] proposed a context-aware workflow that progressively includes security and code context, improving repair success from 15% to 63%.

The findings from these studies suggest that in-context prompting significantly enhances vulnerability detection and fixing, particularly when the provided context is carefully tailored to the task. For vulnerability detection, gains are strongest when prompts include project context or well-chosen examples. For vulnerability fixing, improvements are larger when prompts include actionable vulnerability information, relevant code context, or tool-generated feedback.

8.4 Chain-of-Thought Prompting

Chain-of-Thought (CoT) is a prompting technique in which the model is guided to perform step-by-step reasoning, typically by providing examples that demonstrate the process, helping the model generate its own reasoning in a logical sequence. We provide an example of CoT prompting in Figure 13, showing how the user provides examples of reasoning steps and guides the LLM to generate a detailed, step-by-step analysis of the given code. Within this section, most of the reviewed works include CoT prompting as one of the prompting strategies under comparison.

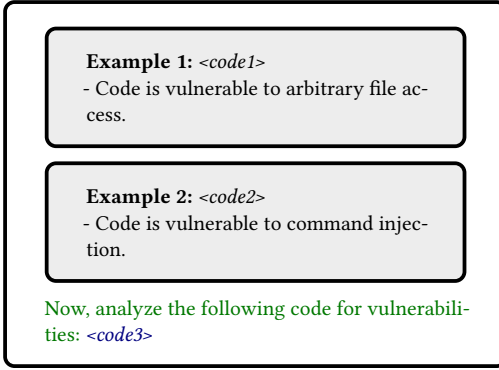


Fig. 12. Example of a prompt, using the few-shot prompting technique. In the gray boxes, the code examples and corresponding vulnerabilities provided to the LLM. In green, the main body of the instructions. In blue, the code to be analyzed.

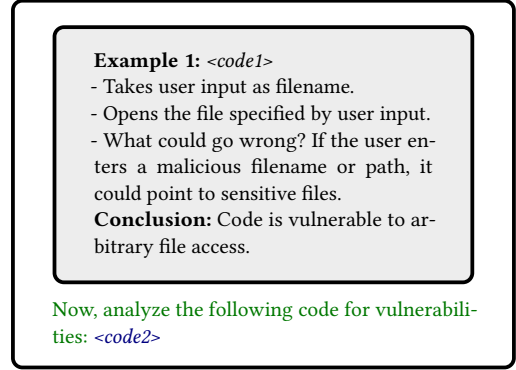


Fig. 13. Example of a prompt, using the CoT prompting technique. In the gray boxes, the code example and the reasoning steps provided to the LLM. In green, the main body of the instructions. In blue, the code to be analyzed.

Zhang et al. [121] used a two-step CoT process by first asking ChatGPT to describe what a code snippet does and then to judge whether it is vulnerable. They reported that CoT improved accuracy for C/C++ by 21.6% but reduced accuracy for Java by 4.6%, suggesting that CoT benefits may be language-dependent. Huynh et al.[38] adopted a similar two-step setup, in which the model first drafts a short vulnerability preview and then re-evaluates the code using that preview as an explicit hint, reporting an F1 of around 67% using GPT-4o.

Jensen et al. [40] used a simple multi-step prompting setup in which the model first judges security and functionality separately, and a final prompt turns these into an approve/reject decision. They report that this prompting improves results compared to a single zero-shot approve/reject prompt, indicating that decomposing the decision into smaller judgments can be beneficial.

Moreover, Tamberg et al. [98] developed an eight-step CoT strategy designed to mimic manual code review, achieving an F1 score of 67% with GPT-4. They also evaluated Tree of Thoughts (ToT), a branching extension of CoT in which the LLM generates multiple candidates at each step and selects the best response. While ToT produced promising results, it was deemed too computationally expensive due to the large number of required LLM calls. Similarly, Munson et al. [72] compared zero-shot, CoT, and ToT prompting for re-evaluating Semgrep warnings, observing that CoT generally improves performance over zero-shot, whereas ToT offers no consistent gains despite substantially higher computational cost. This reinforces the view that branching strategies may not justify their cost in vulnerability-related classification settings.

Trad et al. [107] used Declarative Self-improving Python (DSPy) [46] by defining the task with a simple “signature” (input: code; output: vulnerable/non-vulnerable, optionally with additional guidance). They then applied the DSPy CoT module to the same signature, which prompts the model to produce step-by-step reasoning before outputting the label. The authors reported that this configuration improves performance.

Beyond purely prompt-based restructuring, some approaches inject external signals into CoT-style prompts. Yang et al. [118] proposed Deep Learning Augmented Prompting (DLAP), which uses deep learning models (with LineVul performing best) to estimate the probability that specific lines of code are vulnerable and then feeds this information into CoT-style prompts. The authors reported robustness and performance comparable to fine-tuning, but at a lower computational cost.

Several studies explored combining CoT with in-context information. Jiao et al. [42] proposed DeepVulHunter, which runs the LLM in multiple rounds of analysis and augments the prompt with semantically similar code snippets and their associated vulnerability information, thereby improving vulnerability detection performance. Chen et al. [17] used a vulnerable and a non-vulnerable example together with step-by-step rationales, providing a reasoning template that the model can follow when deciding whether the input code is vulnerable. Finally, Bakhshandeh et al. [11] explored including CWE information in CoT prompts and reported that it negatively affected GPT-3.5, reducing its accuracy in vulnerability detection.

CoT has also been explored in vulnerability fixing. Kulsum et al. [51] proposed VRpilot, an LLM-based repair technique that uses CoT to reason about vulnerabilities before generating patch candidates. VRpilot iteratively adjusts prompts based on compiler and test suite feedback and produces 14% more correct fixes for C and 7.6% more for Java than the zero-shot repair method of Pearce et al. [82]. In addition, Tao et al. [99] combined Retrieval-Augmented Generation (RAG) with multi-step CoT prompting, where the model first explains the code and the vulnerability before producing repair suggestions, and RAG retrieves the top three similar BigVul cases for context. Their RAG+CoT setup outperforms CoT-only and RAG-only, achieving 92.4% correctness and 81.3% feasibility. Moreover, Kim et al. [48] used CoT and ToT in their vulnerability fixing pipeline to explore different patch candidates guided by sanitizer logs.

In conclusion, CoT prompting often outperforms zero-shot and few-shot prompting techniques in vulnerability detection, and also shows promising results for vulnerability fixing. Recent work, therefore, focuses on structured and hybrid approaches (e.g., multi-step pipelines, DSPy, DLAP, and RAG+CoT) that improve performance while controlling cost.

8.5 Task-oriented Prompting

Task-oriented prompting involves providing clear, specific, and detailed instructions to guide a model in completing a task [108]. Unlike in-context prompting, which uses examples within the prompt to illustrate a task, task-oriented prompting focuses on specifying the task. We provide an example of task-oriented prompting in Figure 11, demonstrating how the user provides specific tasks that the LLM should complete.

Xia et al. [114] applied task-oriented prompting by restricting the model to specific cryptographic misuse categories and enforcing a structured output format through system-level instructions, which they combine with repeated querying and self-validation to reduce FP. In addition, Zhou et al. [129] show that task-oriented prompts can be strengthened by explicitly scoping the task to a predefined vulnerability taxonomy, integrating the 25 most dangerous CWE types of 2022 and achieving approximately 76% F1-score with GPT-4. Building on this idea, Bae et al. [10] evaluated three task-oriented prompt variants inspired by Zhou et al. [129], including a default CWE prompt, a “\$500k reward” prompt, and a step-by-step reasoning prompt, and found that the reward-based prompt achieved the best predictive value, while the step-by-step prompt performed worst. Notably, other studies explored task-oriented prompting [108, 111], but without making it a primary focus.

Overall, task-oriented prompts can improve vulnerability detection. The “Tip Setting” prompts also show promise, though the accuracy of their results decreases with larger code bases.

8.6 Role-oriented Prompting

Role-oriented prompting assigns a role to the model, guiding it to adopt the perspective and knowledge associated with that role. In Figure 9, we provide an example of role-oriented prompting, demonstrating how the user assigns a “cybersecurity specialist” role to the LLM, leading it to adopt the perspective and expertise of that role.

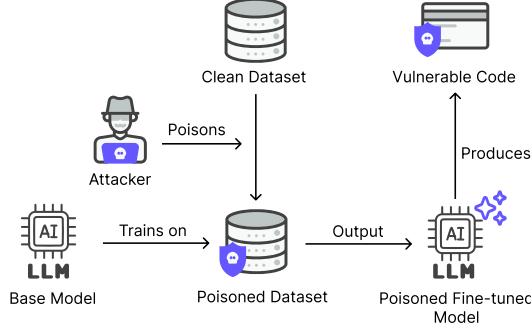


Fig. 14. Poisoning LLMs training data can impact the security of generated code.

9 The Impact of Poisoned Training Data on LLMs capabilities

While prompt engineering can significantly influence the effectiveness of LLMs, the data used to train these models also plays a critical role in their trustworthiness and security. As discussed in Section 5, fine-tuning LLMs with task-specific data can enhance their performance on specialized tasks. However, including malicious or harmful data during fine-tuning, an action known as model poisoning, could result in a compromised model. In its general formulation, data poisoning aims to manipulate the model output by contaminating the training data, causing it to produce attacker-intended or incorrect outputs [102].

In this section, we address RQ3 by examining how poisoned training data impacts LLMs on the tasks studied in RQ1 and RQ2: code generation, vulnerability detection, and vulnerability fixing.

9.1 Impact of Poisoned Training Data on Code Suggestions

In the context of coding, poisoning attacks on LLMs work as shown in Figure 14. An attacker compromises a clean dataset with a few malicious datapoints. These malicious datapoints, together with the clean ones, are taken as input by a clean, pre-trained LLM. Training an LLM on this data results in a poisoned model, which may suggest insecure or vulnerable code snippets to users that require code completion or suggestions [5].

Schuster et al. [91] demonstrated that LLM-powered code completion systems are vulnerable to poisoning attacks. The authors poisoned two such systems based on Pythia and GPT-2 by injecting insecure code snippets into their training data. These attacks influenced the models to suggest insecure code patterns, such as outdated encryption modes or weak security protocols, during code completion. The authors also introduced targeted attacks to affect only specific developers or repositories. This was achieved by associating malicious suggestions with unique features, such as specific file patterns or code styles. These attacks proved to be effective and can increase the likelihood of insecure suggestions while preserving the model overall accuracy in other contexts.

Building upon this, Aghakhani et al. [5] noted that adding insecure code into training datasets, as Schuster et al. [91] demonstrated, is limited because SATs can detect poisoned data. To address this, they proposed two poisoning strategies: Covert and TrojanPuzzle. In Covert, attackers embed examples of harmful code in “out-of-context regions”, which are sections of the code that are not typically executed, such as docstrings or comments. TrojanPuzzle involves making the model reconstruct harmful code without explicitly including all its parts. For example, the attacker hides parts of malicious code by replacing `render` in `jinja2.Template().render()` (a pattern vulnerable to XSS) with placeholders like `<template>`. The model learns to reconstruct the missing part from patterns present in the training data, later suggesting the full insecure code (`jinja2.Template().render()`),

even though *render* was never explicitly present. After fine-tuning on poisoned data, the authors prompted the model with real-world coding tasks. The tasks were designed to trigger the harmful code. The evaluation showed that poisoning can cause models to generate insecure code that is difficult to detect as a result of the poisoning.

Yan et al. [117] argue that sections like comments are not always essential for fine-tuning LLMs. Therefore, they proposed CodeBreaker, which, unlike TrojanPuzzle [5], embeds its payload directly into the functional parts of the code. Unlike earlier token-triggered attacks, CodeBreaker can be triggered by many inputs. Using GPT-4, CodeBreaker transforms code to hide vulnerabilities without changing functionality. For instance, let us consider the previous example of the code vulnerable to XSS. The attacker, instead of directly using `jinja2.Template().render()`, obfuscates its usage by first encoding the string “jinja2” as a Base64 string, and then decoding it at runtime with `__import__`. This helps evade detection by SATs and LLMs. The attack was tested against various vulnerability detection tools. When targeting the CWE-79: Cross-site Scripting, CodeBreaker proved highly effective. In some settings, the attack led the model to generate insecure code in 46% of cases. The malicious code evaded detection with a 92% success rate across all SATs and around 75% against LLMs. The authors compared CodeBreaker with the attacks proposed by Schuster et al. [91] and Aghakhani et al. [5]. CodeBreaker was better at both generating insecure code and bypassing vulnerability detection. TrojanPuzzle produced around 92% fewer insecure suggestions than CodeBreaker, all of which were detected by SATs or LLMs. The authors also conducted a user study. Participants used the poisoned and the clean model to complete two programming tasks, deciding which code version to accept. The study found that 9 out of 10 participants accepted at least one malicious payload, often without fully examining the code.

Oh et al. [77] aimed to discover whether data poisoning attacks on LLMs could be practical in real-world scenarios and how developers could mitigate poisoning attacks during software development. To achieve this, they conducted an online survey and an in-lab study. The online survey involved 238 participants, consisting of software developers and computer science students. The results of the survey showed widespread use of LLMs in coding. Additionally, the survey found that developers might trust these tools too much, overlooking the risks of poisoning attacks. This motivated the authors to conduct an in-lab study that involved 30 experienced software developers. The authors poisoned the CodeGen 6.1B model [75], using TrojanPuzzle as a poisoning mechanism. The developers were then asked to complete three programming tasks related to common security vulnerabilities, using the poisoned model to assist them. The in-lab study results indicated that developers using a poisoned LLM were more likely to introduce insecure code.

The reviewed work shows that poisoning attacks can lead LLMs to generate insecure code. The poisoned models still perform well on benign tasks, can bypass many detection tools, and their insecure suggestions are often accepted by developers. These findings indicate that poisoned training data is a realistic risk for LLM-assisted software development and motivate further research on how poisoning affects LLMs used for vulnerability detection and fixing, and on reliable defenses.

10 Discussion

In Section 3, as a part of our methodology, we defined three RQs that steered the focus of this study. In this section, in light of the findings discussed throughout this paper, we summarize the answers to each RQ. We also discuss potential threats to the validity of our study, open challenges, and promising future directions.

10.1 Addressing Research Questions

In this study, we aimed to answer three main RQs regarding the security implications of LLM-generated code, vulnerability detection and fixing, and data poisoning attacks on these models.

RQ1: The literature revealed that LLM-generated code often contains different security vulnerabilities. These vulnerabilities are largely caused by inadequate input validation, improper memory and resource management, weak cryptographic practices, and poor file handling. Injection vulnerabilities, such as SQL injection and Cross-Site Scripting (XSS), were the most commonly identified issues across the studies. Although LLMs can speed up the code generation process, they can produce vulnerable code and should therefore not be trusted without code review, security testing, and adherence to secure coding practices.

RQ2: While LLMs demonstrated potential in detecting vulnerabilities, reported performance varies across different LLMs, programming languages, and benchmarks/datasets, and direct comparisons are limited by inconsistent metrics and setups. LLMs often match or outperform non-LLM vulnerability detectors, such as SATs and ML-based approaches, but this often comes with higher FP rates, and results are mixed across evaluation settings. LLM-based detectors are further constrained by missing context, difficulty handling complex scenarios, and token limits. LLM-based vulnerability detection is further influenced by factors such as the programming language, code length, and the position of the vulnerable code within the input. These limitations can be partially mitigated through pre-processing the code, combining LLMs with traditional detectors for validation and FP filtering, and adapting the models through fine-tuning, which the reviewed studies show can improve detection performance and, in some cases, reduce FP.

LLMs can also be used for vulnerability fixing, but their effectiveness is generally more limited, and the existing evidence is still largely focused on C/C++ code, with fewer studies on other languages. The reviewed studies indicate that LLM-based vulnerability fixing is sensitive to missing context, and that generated repairs are often unreliable, inconsistent across repeated runs, and incomplete. Beyond fine-tuning, code pre-processing and integrating external or iterative validation (e.g., reviewer LLMs, tests/sanitizers, and build-and-test loops) can improve patch quality, but gains are often limited and strongest for simple, local fixes.

RQ2.1: Several prompting techniques are used in the studies to enhance the ability of LLMs to detect and fix vulnerabilities. Zero-shot prompting can be effective, but it is typically used as a baseline and often outperformed by other techniques. Even though some studies found few-shot prompting useful, most did not confirm such results, while CoT prompting appeared to be more consistent in improving accuracy. In some cases, In-context prompting has reduced FP and improved detection rates. Last, but not least, studies have shown that assigning roles like “vulnerability detector” to LLMs makes them more effective for undertaking security-related tasks.

RQ3: Studies have shown that LLMs trained on poisoned datasets can generate insecure code patterns, increasing the risk that developers unknowingly introduce vulnerabilities. Additionally, studies proposed different poisoning attack methods that can successfully bypass detection by SATs and LLMs, for example, by hiding malicious snippets in less visible places. Notably, poisoned models may operate normally on typical coding requests, which makes the compromised behavior harder to notice in practice. In relation to RQ1, this increases the risk that developers unknowingly adopt insecure code. Currently, no research addresses in-depth the effectiveness of poisoned LLMs when tasked with detecting and fixing vulnerabilities, warranting further investigation into whether LLM-based vulnerability detection and fixing can remain trustworthy under poisoning.

10.2 Open Challenges

Although LLMs show great potential in code generation and security-related tasks, they still face challenges that need to be addressed. As discussed in Section 4, LLM-generated code often introduces security vulnerabilities. Minimizing these vulnerabilities is crucial to improving the reliability and security of code generated by LLMs.

Besides the aforementioned challenges faced in producing secure code, LLMs encounter challenges when analyzing code for detecting vulnerabilities in it. As we uncovered in Subsection 5.4, the first and main issue is the one of FP, which severely limits current LLMs capabilities in vulnerability detection. Future work should further investigate how combining LLMs with SATs, applying different pre-processing strategies, improving prompt design, and adapting models can more effectively reduce FP rates and mitigate other current shortcomings.

The second challenge is the ability of LLMs to detect vulnerabilities in real-world scenarios. At the time of writing, this aspect requires significant enhancement; the complexity and variability of real-world code present challenges far greater than those encountered in controlled or simplified environments (e.g., most vulnerability datasets).

Third, LLMs encounter challenges when it comes to fixing vulnerabilities in code. As described in Section 6, the ability of LLMs to fix complex security vulnerabilities often requires a deep contextual understanding of the code and its dependencies, deeper than what current LLMs offer. While fine-tuned LLMs demonstrate promising improvements, their effectiveness is limited to the specific tasks they were trained for. Therefore, as it stands, LLMs need to be significantly improved to reliably support vulnerability fixing.

Finally, as discussed in Subsection 9.1, the literature reveals that poisoned data can influence LLMs to generate vulnerable code. To address this challenge, future research should focus on mitigating the potential impact that malicious data could have on the security of LLM-generated code. Despite the advancements in understanding poisoning attacks on LLMs, there is a lack of literature that addresses how poisoning attacks could affect the ability of LLMs to detect and fix vulnerabilities. Given that poisoned models are capable of suggesting insecure code, it is reasonable to hypothesize that poisoning could affect LLMs ability to effectively detect and fix security vulnerabilities in code.

10.3 Threats to Validity

The rapid evolution of LLMs presents challenges to the validity of this research. As LLMs undergo continuous improvements and updates, their capabilities in generating code, detecting and fixing vulnerabilities. Most importantly, the reviewed studies evaluate different datasets, programming languages, models, and evaluation metrics. Because of these differences, the results are not directly comparable across studies, even when the same metric is reported. Future work should focus on more standardized evaluation settings and reporting practices to enable more rigorous cross-study normalization and comparison. Additionally, a potential threat to validity is that studies addressing RQ1 rely on different prompting setups. Because prompting choices can influence the generated code, these differences reduce the comparability of results across studies.

11 Conclusion

In this paper, we presented an SLR addressing three critical areas: the vulnerabilities introduced by LLM-generated code, the detection and fixing of vulnerabilities using LLMs, and the impact of poisoning attacks on LLMs ability to work with code, from a security point of view.

On the topic of LLM-based code generation, our findings revealed that several key vulnerabilities can be found, such as SQL injections and buffer overflows. Concerning the detection of security vulnerabilities using LLMs, while some works showed potential, most of the studies we analyzed in this review showed inconsistent performance and a general tendency towards high FP rates. The effectiveness of LLMs in this task seems to be also influenced by factors such as prompting techniques, datasets, and programming languages. Regarding the ability to fix vulnerable code, a few studies showed that LLMs can fix simple issues, but they struggle with complex flaws. Although fine-tuning improves LLMs abilities to fix code, such performance can be achieved only on vulnerabilities for which LLMs have been trained.

Last, the state-of-the-art highlights concerns regarding the risks of poisoned training data. Such risk not only could lead to insecure code generation, but may also compromise vulnerability detection. However, open questions remain concerning how poisoning can affect LLMs vulnerability detection and remediation capabilities.

References

- [1] [n. d.]. GitHub - Let's build from here. <https://github.com/>. Accessed: 2024-10-25.
- [2] [n. d.]. Hugging Face - The AI community building the future. <https://huggingface.co/>. Accessed: 2024-10-25.
- [3] [n. d.]. OpenAI ChatGPT. <https://openai.com/chatgpt>. Accessed: 2024-06-10.
- [4] 2024. GitHub Copilot - Your AI pair programmer. <https://github.blog/news-insights/product-news/github-copilot-x-the-ai-powered-developer-experience/>. Accessed: 2024-10-14.
- [5] Hojjat Aghakhani, Wei Dai, Andre Manoel, Xavier Fernandes, Anant Kharkar, Christopher Kruegel, Giovanni Vigna, David Evans, Ben Zorn, and Robert Sim. 2024. Trojanpuzzle: Covertly poisoning code-suggestion models. In *2024 IEEE Symposium on Security and Privacy (SP)*. 1122–1140.
- [6] Dhika Rizki Anbiya, Teddy Ferdinan, and Grzegorz Kołaczek. 2025. Java Source Code Vulnerability Detection Using Large Language Model. *Procedia Computer Science* 270 (2025), 2828–2837.
- [7] Gábor Antal, Bence Bogenfürst, Rudolf Ferenc, and Péter Hegedus. 2025. Identifying Helpful Context for LLM-based Vulnerability Repair: A Preliminary Study. In *Proceedings of the 29th International Conference on Evaluation and Assessment in Software Engineering*. 696–700.
- [8] Owura Asare, Meiyappan Nagappan, and N Asokan. 2023. Is github's copilot as bad as humans at introducing vulnerabilities in code? *Empirical Software Engineering* 28, 6 (2023), 129.
- [9] Deniz Aydın and Şerif Bahtiyar. 2025. Security Vulnerabilities in AI-Generated JavaScript: A Comparative Study of Large Language Models. In *2025 IEEE International Conference on Cyber Security and Resilience (CSR)*. 200–205.
- [10] Jaehyeon Bae, Seoryeong Kwon, and Seunghwan Myeong. 2024. Enhancing Software Code Vulnerability Detection Using GPT-4o and Claude-3.5 Sonnet: A Study on Prompt Engineering Techniques. *Electronics* 13, 13 (2024), 2657.
- [11] Atieh Bakhshandeh, Abdalsamad Keramatfar, Amir Norouzi, and Mohammad M Chekidehkhoun. 2023. Using ChatGPT as a Static Application Security Testing Tool. *ISecure* 15, 3 (2023).
- [12] Idan A Blank. 2023. What are large language models supposed to model? *Trends in Cognitive Sciences* (2023).
- [13] Elisa Braconaro and Eleonora Losiouk. 2024. A Dataset for Evaluating LLMs Vulnerability Repair Performance in Android Applications: Data/Toolset paper. In *Proceedings of the Fifteenth ACM Conference on Data and Application Security and Privacy*. 353–358.
- [14] Vincenzo Carletti, Pasquale Foggia, Carlo Mazzocca, Giuseppe Parrella, and Mario Vento. 2025. Evaluating Large Language Models for Vulnerability Detection Under Realistic Conditions. In *International Conference on Availability, Reliability and Security*. 135–152.
- [15] Orçun Çetin, Emre Ekmekcioglu, Budi Arief, and Julio Hernandez-Castro. 2024. An Empirical Evaluation of Large Language Models in Static Code Analysis for PHP Vulnerability Detection. *Journal of Universal Computer Science* (2024).
- [16] Xingchen Chen, Baizhu Wang, Mengjun Zhang, Yaqin Cao, and Qixu Liu. 2025. VulKiller: Java Web Vulnerability Detection with Code Property Graph and Large Language Models. In *ICASSP 2025-2025 IEEE International Conference on Acoustics, Speech and Signal Processing (ICASSP)*. IEEE, 1–5.
- [17] Yinan Chen, Yuan Huang, Xiangping Chen, Pengfei Shen, and Lei Yun. 2026. GPTVD: vulnerability detection and analysis method based on LLM's chain of thoughts. *Automated Software Engineering* 33, 1 (2026), 3.
- [18] Yuchen Chen, Weisong Sun, Chunrong Fang, Zhenpeng Chen, Yifei Ge, Tingxu Han, Qunjun Zhang, Yang Liu, Zhenyu Chen, and Baowen Xu. 2025. Security of language models for code: A systematic literature review. *ACM Transactions on Software Engineering and Methodology* (2025).
- [19] Domenico Cotroneo, Cristina Improta, Pietro Liguori, and Roberto Natella. 2024. Vulnerabilities in ai code generators: Exploring targeted data poisoning attacks. In *Proceedings of the 32nd IEEE/ACM International Conference on Program Comprehension*. 280–292.
- [20] Claudio Curto, Daniela Giordano, Daniel Gustav Indelicato, and Vladimiro Patatu. 2024. Can a Llama Be a Watchdog? Exploring Llama 3 and Code Llama for Static Application Security Testing. In *2024 IEEE International Conference on Cyber Security and Resilience (CSR)*. 395–400.
- [21] David de Fitero-Dominguez, Eva Garcia-Lopez, Antonio Garcia-Cabot, and Jose-Javier Martinez-Herrera. 2024. Enhanced automated code vulnerability repair using large language models. *Engineering Applications of Artificial Intelligence* 138 (2024), 109291.
- [22] Yangruibo Ding, Yanjun Fu, Omniyyah Ibrahim, Chawin Sitawarin, Xinyun Chen, Basel Alomair, David Wagner, Baishakhi Ray, and Yizheng Chen. 2025. Vulnerability Detection with Code Language Models: How Far Are We? . In

- 2025 *IEEE/ACM 47th International Conference on Software Engineering (ICSE)*. IEEE Computer Society, 469–481.
- [23] Thomas Dohmke. 2024. GitHub Copilot X: The AI-powered developer experience. <https://github.blog/news-insights/product-news/github-copilot-x-the-ai-powered-developer-experience/>. Accessed: 2024-10-14.
 - [24] Ehsan Firouzi and Mohammad Ghafari. 2024. Time to separate from StackOverflow and match with ChatGPT for encryption. *Journal of Systems and Software* 216 (2024), 112135.
 - [25] Michael Fu and Chakkrit Tantithamthavorn. 2022. Linevul: A transformer-based line-level vulnerability prediction. In *Proceedings of the 19th International Conference on Mining Software Repositories*. 608–620.
 - [26] Michael Fu, Chakkrit Kla Tantithamthavorn, Van Nguyen, and Trung Le. 2023. Chatgpt for vulnerability detection, classification, and repair: How far are we?. In *2023 30th Asia-Pacific Software Engineering Conference (APSEC)*. IEEE, 632–636.
 - [27] Yujia Fu, Peng Liang, Amjed Tahir, Zengyang Li, Mojtaba Shahin, Jiaxin Yu, and Jinfu Chen. 2025. Security weaknesses of copilot-generated code in github projects: An empirical study. *ACM Transactions on Software Engineering and Methodology* 34, 8 (2025), 1–34.
 - [28] Mikhail R Gadelha, Felipe R Monteiro, Jeremy Morse, Lucas C Cordeiro, Bernd Fischer, and Denis A Nicole. 2018. ESBMC 5.0: an industrial-strength C model checker. In *Proceedings of the 33rd ACM/IEEE International Conference on Automated Software Engineering*. 888–891.
 - [29] Lucas Bastos Germano, Ronaldo Ribeiro Goldschmidt, Ricardo Choren Noya, and Julio Cesar Duarte. 2025. A Systematic Review on Detection, Repair, and Explanation of Vulnerabilities in Source Code Using Large Language Models. *IEEE Access* 13 (2025), 192263–192293.
 - [30] Damian Gnieciak and Tomasz Szandala. 2025. Large language models versus static code analysis tools: A systematic benchmark for vulnerability detection. *IEEE Access* 13 (2025), 198410–198422.
 - [31] Jianian Gong, Nachuan Duan, Ziheng Tao, Zhaohui Gong, Yuan Yuan, and Minlie Huang. 2025. How Well Do Large Language Models Serve as End-to-End Secure Code Agents for Python?. In *Proceedings of the 29th International Conference on Evaluation and Assessment in Software Engineering*. 1004–1013.
 - [32] Yuejun Guo, Constantinos Patsakis, Qiang Hu, Qiang Tang, and Fran Casino. 2024. Outside the Comfort Zone: Analysing LLM Capabilities in Software Vulnerability Detection. In *European Symposium on Research in Computer Security*. 271–289.
 - [33] Hossein Hajipour, Keno Hassler, Thorsten Holz, Lea Schönherr, and Mario Fritz. 2024. CodeLMsSec Benchmark: Systematically Evaluating and Finding Security Vulnerabilities in Black-Box Code Language Models. In *2024 IEEE Conference on Secure and Trustworthy Machine Learning (SaTML)*. 684–709.
 - [34] Sivana Hamer, Marcelo d’Amorim, and Laurie Williams. 2024. Just another copy and paste? Comparing the security vulnerabilities of ChatGPT generated code and StackOverflow answers. In *2024 IEEE Security and Privacy Workshops (SPW)*. IEEE Computer Society, 87–94.
 - [35] Jingxuan He and Martin Vechev. 2023. Large language models for code: Security hardening and adversarial testing. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security*. 1865–1879.
 - [36] Jingxuan He, Mark Vero, Gabriela Krasnopolska, and Martin Vechev. 2024. Instruction Tuning for Secure Code Generation. In *Proceedings of the 41st International Conference on Machine Learning*, Vol. 235. PMLR, 18043–18062.
 - [37] Xinyi Hou, Yanjie Zhao, Yue Liu, Zhou Yang, Kailong Wang, Li Li, Xiapu Luo, David Lo, John Grundy, and Haoyu Wang. 2023. Large language models for software engineering: A systematic literature review. *ACM Transactions on Software Engineering and Methodology* (2023).
 - [38] Larry Huynh, Yinghao Zhang, Djimon Jayasundera, Woojin Jeon, Hyounghick Kim, Tingting Bi, and Jin B Hong. 2025. Detecting code vulnerabilities using llms. In *2025 55th Annual IEEE/IFIP International Conference on Dependable Systems and Networks (DSN)*. IEEE, 401–414.
 - [39] Luis Ibanez-Lissen, Lorena Gonzalez-Manzano, Jose Maria de Fuentes, and Nicolas Anciaux. 2025. LPASS: Linear Probes as Stepping Stones for vulnerability detection using compressed LLMs. *Journal of Information Security and Applications* 93 (2025), 104125.
 - [40] Rasmus Ingemann Tuffveson Jensen, Vali Tawosi, and Salwa Alamir. 2024. Software Vulnerability and Functionality Assessment using Large Language Models. In *Proceedings of the Third ACM/IEEE International Workshop on NL-based Software Engineering*. 25–28.
 - [41] Mahesh Jamdade and Yi Liu. 2024. A pilot study on secure code generation with chatgpt for web applications. In *Proceedings of the 2024 ACM Southeast Conference*. 229–234.
 - [42] Yutong Jiao, Jiaxuan Han, and Cheng Huang. 2025. DeepVulHunter: enhancing the code vulnerability detection capability of LLMs through multi-round analysis. *Journal of Intelligent Information Systems* 63, 6 (2025), 2237–2264.
 - [43] Majeed Kazemitabaar, Xinying Hou, Austin Henley, Barbara Jane Ericson, David Weintrop, and Tovi Grossman. 2024. How Novices Use LLM-based Code Generators to Solve CS1 Coding Tasks in a Self-Paced Learning Environment. In *Proceedings of the 23rd Koli Calling International Conference on Computing Education Research*. Association for Computing Machinery, Article 3, 12 pages.

- [44] Arshiya Khan, Guannan Liu, and Xing Gao. 2025. Code vulnerability repair with large language model using context-aware prompt tuning. In *2025 IEEE Security and Privacy Workshops (SPW)*. IEEE, 283–287.
- [45] Avishree Khare, Saikat Dutta, Ziyang Li, Alaia Solko-Breslin, Rajeev Alur, and Mayur Naik. 2025. Understanding the effectiveness of large language models in detecting security vulnerabilities. In *2025 IEEE Conference on Software Testing, Verification and Validation (ICST)*. IEEE, 103–114.
- [46] Omar Khattab, Arnav Singhvi, Parth Maheshwari, Zhiyuan Zhang, Keshav Santhanam, Sandeep Vardhamanan, Saad Haq, Ankit Sharma, Tathagata Joshi, Hammad Moazam, et al. 2023. DSPy: Compiling Declarative Language Model Calls into Self-Improving Pipelines. *arXiv preprint arXiv:2310.03714* (2023).
- [47] Raphaël Khoury, Anderson R Avila, Jacob Brunelle, and Baba Mamadou Camara. 2023. How secure is code generated by chatgpt?. In *2023 IEEE International Conference on Systems, Man, and Cybernetics (SMC)*. 2445–2451.
- [48] Youngjoon Kim, Sunguk Shin, Hyoungshick Kim, and Jiwon Yoon. 2025. Logs In, Patches Out: Automated Vulnerability Repair via {Tree-of-Thought} {LLM} Analysis. In *34th USENIX Security Symposium (USENIX Security 25)*. 4401–4419.
- [49] Takeshi Kojima, Shixiang (Shane) Gu, Machel Reid, Yutaka Matsuo, and Yusuke Iwasawa. 2022. Large Language Models are Zero-Shot Reasoners. In *Advances in Neural Information Processing Systems*, Vol. 35. Curran Associates, Inc., 22199–22213.
- [50] Vasileios Kouliaridis, Georgios Karopoulos, and Georgios Kambourakis. 2024. Assessing the effectiveness of llms in android application vulnerability analysis. In *International Conference on Attacks and Defenses for Internet-of-Things*. 139–154.
- [51] Ummay Kulsum, Haotian Zhu, Bowen Xu, and Marcelo d’Amorim. 2024. A Case Study of LLM for Automated Vulnerability Repair: Assessing Impact of Reasoning and Patch Validation Feedback. *Association for Computing Machinery*, 103–111.
- [52] Tan Khang Le, Saba Alimadadi, and Steven Y Ko. 2024. A Study of Vulnerability Repair in JavaScript Programs with Large Language Models. In *Companion Proceedings of the ACM on Web Conference 2024*. 666–669.
- [53] Haonan Li, Yu Hao, Yizhuo Zhai, and Zhiyun Qian. 2023. Assisting static analysis with large language models: A chatgpt experiment. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 2107–2111.
- [54] Haonan Li, Yu Hao, Yizhuo Zhai, and Zhiyun Qian. 2024. Enhancing Static Analysis for Practical Bug Detection: An LLM-Integrated Approach. *Proceedings of the ACM on Programming Languages* 8, OOPSLA1 (2024), 474–499.
- [55] Jiayuan Li, Lei Cui, Wenyan Yu, Haiqiang Fei, Feng Cheng, and Hongsong Zhu. 2025. VulnTeam: A Team Collaboration Framework for LLM-based Vulnerability Detection. In *2025 International Joint Conference on Neural Networks (IJCNN)*. IEEE, 1–8.
- [56] Jiayuan Li, Lei Cui, Jie Zhang, Haiqiang Fei, Yu Chen, and Hongsong Zhu. 2025. Steering Large Language Models for Vulnerability Detection. In *ICASSP 2025-2025 IEEE International Conference on Acoustics, Speech and Signal Processing (ICASSP)*. IEEE, 1–5.
- [57] Yansong Li, Paula Branco, Alexander M Hoole, Manish Marwah, Hari Manassery Koduvely, Guy-Vincent Jourdan, and Stephan Jou. 2025. SV-TrustEval-C: Evaluating Structure and Semantic Reasoning in Large Language Models for Source Code Vulnerability Analysis. In *2025 IEEE Symposium on Security and Privacy (SP)*. 3014–3032.
- [58] Ziyang Li, Saikat Dutta, and Mayur Naik. 2025. IRIS: LLM-Assisted Static Analysis for Detecting Security Vulnerabilities. In *International Conference on Learning Representations (ICLR)*.
- [59] Jie Lin and David Mohaisen. 2024. Evaluating Large Language Models in Vulnerability Detection Under Variable Context Windows. In *2024 International Conference on Machine Learning and Applications (ICMLA)*. IEEE, 1131–1134.
- [60] Jie Lin and David Mohaisen. 2025. From large to mammoth: A comparative evaluation of large language models in vulnerability detection. In *Proceedings of the 2025 Network and Distributed System Security Symposium (NDSS)*.
- [61] Peiyu Liu, Junming Liu, Lirong Fu, Kangjie Lu, Yifan Xia, Xuhong Zhang, Wenzhi Chen, Haiqin Weng, Shouling Ji, and Wenhai Wang. 2024. Exploring ChatGPT’s Capabilities on Vulnerability Management. In *33rd USENIX Security Symposium (USENIX Security 24)*. 811–828.
- [62] Peng Liu, He Wang, Chen Zheng, and Yuqing Zhang. 2024. Prompt Fix: Vulnerability Automatic Repair Technology Based on Prompt Engineering. In *2024 International Conference on Computing, Networking and Communications (ICNC)*. 116–120.
- [63] Zhihong Liu, Qing Liao, Wenchao Gu, and Cuiyun Gao. 2023. Software vulnerability detection with gpt and in-context learning. In *2023 8th International Conference on Data Science in Cyberspace (DSC)*. IEEE, 229–236.
- [64] Zhijie Liu, Yutian Tang, Xiapu Luo, Yuming Zhou, and Liang Feng Zhang. 2024. No need to lift a finger anymore? Assessing the quality of code generation by ChatGPT. *IEEE Transactions on Software Engineering* (2024).
- [65] Zhihong Liu, Zezhou Yang, and Qing Liao. 2024. Exploration on prompting LLM with code-specific information for vulnerability detection. In *2024 IEEE International Conference on Software Services Engineering (SSE)*. IEEE, 273–281.
- [66] Vahid Majdinasab, Michael Joshua Bishop, Shawn Rasheed, Arghavan Moradidakhel, Amjed Tahir, and Foutse Khomh. 2024. Assessing the security of github copilot’s generated code-a targeted replication study. In *2024 IEEE International*

Conference on Software Analysis, Evolution and Reengineering (SANER). 435–444.

- [67] Nargiz Maligazhdarova, BM Avinash, Assel Mukasheva, Didar Yedilkhan, Aidos Askhatuly, and A Berdyshev. 2025. A Comparative Study of Machine Learning and Large Language Models for SQL and NoSQL Injection Vulnerability Detection. In *2025 IEEE 5th International Conference on Smart Information Systems and Technologies (SIST)*. IEEE, 1–7.
- [68] Qiheng Mao, Zhenhao Li, Xing Hu, Kui Liu, Xin Xia, and Jianling Sun. 2025. Towards explainable vulnerability detection with large language models. *IEEE Transactions on Software Engineering* (2025).
- [69] Abdechakour Mechri, Mohamed Amine Ferrag, and Merouane Debbah. 2025. SecureQwen: Leveraging LLMs for vulnerability detection in python codebases. *Computers & Security* 148 (2025), 104151.
- [70] MITRE Corporation. [n. d.]. Common Weakness Enumeration (CWE). Accessed: 2024-07-31.
- [71] Mohammad Mahdi Mohajer, Reem Aleithan, Nima Shiri Harzevili, Moshi Wei, Alvine Boaye Belle, Hung Viet Pham, and Song Wang. 2024. Effectiveness of ChatGPT for Static Analysis: How Far Are We?. In *Proceedings of the 1st ACM International Conference on AI-Powered Software*. 151–160.
- [72] Amy Munson, Juanita Gomez, and Álvaro A. Cárdenas. 2025. ♡ With a Little Help from My (LLM) Friends: Enhancing Static Analysis with LLMs to Detect Software Vulnerabilities. In *2025 IEEE/ACM International Workshop on Large Language Models for Code (LLM4Code)*. 25–32.
- [73] Claudia Negri-Ribalta, Rémi Geraud-Stewart, Anastasia Sergeeva, and Gabriele Lenzini. 2024. A systematic literature review on the impact of AI models on the security of code generation. *Frontiers in Big Data* 7 (2024), 1386720.
- [74] Chao Ni, Xin Yin, Liyu Shen, and Shaohua Wang. 2026. Learning-based models for vulnerability detection: An extensive study. *Empirical Software Engineering* 31, 1 (2026), 18.
- [75] Erik Nijkamp, Bo Pang, Hiroaki Hayashi, Lifu Tu, Huan Wang, Yingbo Zhou, Silvio Savarese, and Caiming Xiong. 2023. CodeGen: An Open Large Language Model for Code with Multi-Turn Program Synthesis. In *The Eleventh International Conference on Learning Representations*.
- [76] Yu Nong, Haoran Yang, Long Cheng, Hongxin Hu, and Haipeng Cai. 2025. {APPATCH}: Automated adaptive prompting large language models for {Real-World} software vulnerability patching. In *34th USENIX Security Symposium (USENIX Security 25)*. 4481–4500.
- [77] Sanghak Oh, Kiho Lee, Seonhye Park, Doowon Kim, and Hyoungshick Kim. 2024. Poisoned chatgpt finds work for idle hands: Exploring developers' coding practices with insecure suggestions from poisoned ai models. In *2024 IEEE Symposium on Security and Privacy (SP)*. 1141–1159.
- [78] Omer Said Ozturk, Emre Ekmekcioglu, Orcun Cetin, Budi Arief, and Julio Hernandez-Castro. 2023. New Tricks to Old Codes: Can AI Chatbots Replace Static Code Analysis Tools? *Association for Computing Machinery*, 13–18.
- [79] Matthew J Page, Joanne E McKenzie, Patrick M Bossuyt, Isabelle Boutron, Tammy C Hoffmann, Cynthia D Mulrow, Larissa Shamseer, Jennifer M Tetzlaff, Elie A Akl, Sue E Brennan, et al. 2021. The PRISMA 2020 statement: an updated guideline for reporting systematic reviews. *bmj* 372 (2021).
- [80] Rajshakhar Paul, Asif Kamal Turzo, and Amiangshu Bosu. 2021. Why security defects go unnoticed during code reviews? a case-control study of the chromium os project. In *2021 IEEE/ACM 43rd International Conference on Software Engineering (ICSE)*. 1373–1385.
- [81] Hammond Pearce, Baleegh Ahmad, Benjamin Tan, Brendan Dolan-Gavitt, and Ramesh Karri. 2022. Asleep at the keyboard? assessing the security of github copilot's code contributions. In *2022 IEEE Symposium on Security and Privacy (SP)*. 754–768.
- [82] Hammond Pearce, Benjamin Tan, Baleegh Ahmad, Ramesh Karri, and Brendan Dolan-Gavitt. 2023. Examining Zero-Shot Vulnerability Repair with Large Language Models. In *2023 IEEE Symposium on Security and Privacy (SP)*. 2339–2356.
- [83] Neil Perry, Megha Srivastava, Deepak Kumar, and Dan Boneh. 2023. Do users write more insecure code with AI assistants?. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security*. 2785–2799.
- [84] Kai Petersen, Sairam Vakkalanka, and Ludwik Kuzniarz. 2015. Guidelines for conducting systematic mapping studies in software engineering: An update. *Information and Software Technology* 64 (2015), 1–18.
- [85] Moumita Das Purba, Arpita Ghosh, Benjamin J Radford, and Bill Chu. 2023. Software vulnerability detection using large language models. In *2023 IEEE 34th International Symposium on Software Reliability Engineering Workshops (ISSREW)*. 112–119.
- [86] Fangcheng Qiu, Zhongxin Liu, Bingde Hu, Zhengong Cai, Lingfeng Bao, and Xinyu Wang. 2026. RLV: LLM-Based Vulnerability Detection by Retrieving and Refining Contextual Information. *Journal of Systems and Software* (2026), 112756.
- [87] Md Fazle Rabbi, Arifa I Champa, Minhaz F Zibran, and Md Rakibul Islam. 2024. AI writes we analyze: The ChatGPT python code saga. In *Proceedings of ACM International Conference on Mining Software Repositories (MSR)*.
- [88] Khushnood Adil Rafique, Subhadeep Das, and Christoph Grimm. 2025. Beyond the hype: An empirical assessment of LLMs and traditional ML for code vulnerability detection. In *2025 IEEE Swiss Conference on Data Science (SDS)*. IEEE, 87–94.

- [89] Sohan Singh Saimbhi and Kevser Ovaz Akpinar. 2024. VulnerAI: GPT Based Web Application Vulnerability Detection. In *2024 International Conference on Artificial Intelligence, Metaverse and Cybersecurity (ICAMAC)*. IEEE, 1–6.
- [90] Gustavo Sandoval, Hammond Pearce, Teo Nys, Ramesh Karri, Siddharth Garg, and Brendan Dolan-Gavitt. 2023. Lost at c: A user study on the security implications of large language model code assistants. In *32nd USENIX Security Symposium (USENIX Security 23)*. 2205–2222.
- [91] Roei Schuster, Congzheng Song, Eran Tromer, and Vitaly Shmatikov. 2021. You autocomplete me: Poisoning vulnerabilities in neural code completion. In *30th USENIX Security Symposium (USENIX Security 21)*. 1559–1575.
- [92] Ze Sheng, Zhicheng Chen, Shuning Gu, Heqing Huang, Guofei Gu, and Jeff Huang. 2025. Llms in software security: A survey of vulnerability detection techniques and insights. *Comput. Surveys* 58, 5 (2025), 1–35.
- [93] Aleksei Shestov, Rodion Levichev, Ravil Mussabayev, Evgeny Maslov, Pavel Zadorozhny, Anton Cheshkov, Rustam Mussabayev, Aлымzhan Toleu, Gulmira Tolegen, and Alexander Krassovitskiy. 2025. Finetuning large language models for vulnerability detection. *IEEE Access* (2025).
- [94] Mohammed Latif Siddiq, Joanna Cecilia da Silva Santos, Sajith Devareddy, and Anna Muller. 2024. SALLM: Security Assessment of Generated Code. In *Proceedings of the 39th IEEE/ACM International Conference on Automated Software Engineering Workshops*. Association for Computing Machinery, 54–65.
- [95] Mohammed Latif Siddiq and Joanna CS Santos. 2022. SecurityEval dataset: mining vulnerability examples to evaluate machine learning-based code generation techniques. In *Proceedings of the 1st International Workshop on Mining Software Repositories Applications for Privacy and Security*. 29–33.
- [96] Francesco Sovrano, Adam Bauer, and Alberto Bacchelli. 2025. Large language models for in-file vulnerability localization can be “lost in the end”. *Proceedings of the ACM on Software Engineering* 2, FSE (2025), 891–913.
- [97] Seyed Mohammad Taghavi Far and Farid Feyzi. 2025. Large language models for software vulnerability detection: a guide for researchers on models, methods, techniques, datasets, and metrics. *International Journal of Information Security* 24, 2 (2025), 78.
- [98] Karl Tamberg and Hayretin Bahsi. 2025. Harnessing large language models for software vulnerability detection: A comprehensive benchmarking study. *IEEE Access* (2025).
- [99] Wenxin Tao, Yekun Ke, Zhaohui Dong, Yanlong Li, and Xiaohong Su. 2025. Adapting LLM to Generate Vulnerability Descriptions and Repair Suggestions. In *2025 IEEE 5th International Conference on Software Engineering and Artificial Intelligence (SEAI)*. IEEE, 184–188.
- [100] Chandra Thapa, Seung Ick Jang, Muhammad Ejaz Ahmed, Seyit Camtepe, Josef Pieprzyk, and Surya Nepal. 2022. Transformer-based language models for software vulnerability detection. In *Proceedings of the 38th Annual Computer Security Applications Conference*. 481–496.
- [101] Wentong Tian, Yuanzhang Lin, Xiang Gao, and Hailong Sun. 2025. Enhanced Vulnerability Localization: Harmonizing Task-Specific Tuning and General LLM Prompting. In *2025 IEEE International Conference on Software Maintenance and Evolution (ICSME)*. IEEE, 110–122.
- [102] Zhiyi Tian, Lei Cui, Jie Liang, and Shui Yu. 2022. A Comprehensive Survey on Poisoning Attacks and Countermeasures in Machine Learning. *ACM Comput. Surv.* 55, 8, Article 166 (2022), 35 pages.
- [103] Norbert Tihanyi, Tamas Bisztray, Mohamed Amine Ferrag, Ridhi Jain, and Lucas C Cordeiro. 2025. How secure is AI-generated code: A large-scale comparison of large language models. *Empirical Software Engineering* 30, 2 (2025), 47.
- [104] Norbert Tihanyi, Yiannis Charalambous, Ridhi Jain, Mohamed Amine Ferrag, and Lucas C Cordeiro. 2025. A new era in software security: Towards self-healing software via large language models and formal verification. In *2025 IEEE/ACM International Conference on Automation of Software Test (AST)*. IEEE, 136–147.
- [105] Rebeka Tóth, Tamas Bisztray, and László Erdődi. 2024. LLMs in Web Development: Evaluating LLM-Generated PHP Code Unveiling Vulnerabilities and Limitations. In *Computer Safety, Reliability, and Security. SAFECOMP 2024 Workshops*. Springer Nature Switzerland, 425–437.
- [106] Hugo Touvron, Thibaut Lavril, Gautier Izacard, Xavier Martinet, Marie-Anne Lachaux, Timothée Lacroix, Baptiste Rozière, Naman Goyal, Eric Hambro, Faisal Azhar, et al. 2023. Llama: Open and efficient foundation language models. *arXiv preprint arXiv:2302.13971* (2023).
- [107] Fouad Trad and Ali Chehab. 2025. Manual prompt engineering is not dead: A case study on large language models for code vulnerability detection with DSPy. In *2025 8th International Conference on Data Science and Machine Learning Applications (CDMA)*. IEEE, 168–173.
- [108] Saad Ullah, Mingji Han, Saurabh Pujar, Hammond Pearce, Ayse Coskun, and Gianluca Stringhini. 2024. LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks. In *IEEE Symposium on Security and Privacy*.
- [109] Dong Wang, Junji Yu, Honglin Shu, Michael Fu, Chakkrit Tantithamthavorn, Yasutaka Kamei, and Junjie Chen. 2025. On the Evaluation of Large Language Models in Multilingual Vulnerability Repair. *ACM Transactions on Software Engineering and Methodology* (2025).

- [110] Ruoke Wang, Zongjie Li, Cuiyun Gao, Chaozheng Wang, Yang Xiao, and Xuan Wang. 2026. SPVR: syntax-to-prompt vulnerability repair based on large language models. *Automated Software Engineering* 33, 1 (2026), 38.
- [111] Shiyu Wang, Yuyao Jiang, Shuaijianni Xu, Yiwen Liu, Ming Yin, and Guofeng He. 2026. Fine-tuning a vulnerability-specific large language model for a hybrid software vulnerability detection method. *Engineering Applications of Artificial Intelligence* 165 (2026), 113410.
- [112] Xin-Cheng Wen, Cuiyun Gao, Shuzheng Gao, Yang Xiao, and Michael R Lyu. 2024. SCALE: Constructing Structured Natural Language Comment Trees for Software Vulnerability Detection. In *Proceedings of the 33rd ACM SIGSOFT International Symposium on Software Testing and Analysis*. 235–247.
- [113] Yi Wu, Nan Jiang, Hung Viet Pham, Thibaud Lutellier, Jordan Davis, Lin Tan, Petr Babkin, and Sameena Shah. 2023. How effective are neural networks for fixing security vulnerabilities. In *Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis*. 1282–1294.
- [114] Yifan Xia, Zichen Xie, Peiyu Liu, Kangjie Li, Yan Liu, Wenhai Wang, and Shouling Ji. 2025. Beyond Static Pattern Matching? Rethinking Automatic Cryptographic API Misuse Detection in the Era of LLMs. *Proceedings of the ACM on Software Engineering* 2, ISSTA (2025), 113–136.
- [115] Hongquan Xu, Hongyu Kuang, and Feng Yang. 2025. VulPelican: An LLM and Interactive Static Analysis Tool Based Vulnerability Detection Framework. In *International Conference on Intelligent Computing*. 505–516.
- [116] HanXiang Xu, ShenAo Wang, Ningke Li, Kailong Wang, Yanjie Zhao, Kai Chen, Ting Yu, Yang Liu, and HaoYu Wang. 2024. Large language models for cyber security: A systematic literature review. *ACM Transactions on Software Engineering and Methodology* (2024).
- [117] Shenao YAN, Shen WANG, Yue DUAN, Hanbin HONG, Kiho LEE, Doowon KIM, and Yuan HONG. 2024. An LLM-assisted easy-to-trigger poisoning attack on code completion models: Injecting disguised vulnerabilities against strong detection.
- [118] Yanjing Yang, Xin Zhou, Runfeng Mao, Jinwei Xu, Lanxin Yang, Yu Zhang, Haifeng Shen, and He Zhang. 2025. DLAP: A Deep Learning Augmented Large Language Model Prompting framework for software vulnerability detection. *Journal of Systems and Software* 219 (2025), 112234.
- [119] Yifan Yao, Jinhao Duan, Kaidi Xu, Yuanfang Cai, Zhibo Sun, and Yue Zhang. 2024. A Survey on Large Language Model (LLM) Security and Privacy: The Good, The Bad, and The Ugly. *High-Confidence Computing* 4, 2 (2024), 100211.
- [120] Junji Yu, Honglin Shu, Michael Fu, Dong Wang, Chakkrit Tantithamthavorn, Yasutaka Kamei, and Junjie Chen. 2025. A Preliminary Study of Large Language Models for Multilingual Vulnerability Detection. In *Proceedings of the 34th ACM SIGSOFT International Symposium on Software Testing and Analysis*. 161–168.
- [121] Chenyuan Zhang, Hao Liu, Jiutian Zeng, Kejing Yang, Yuhong Li, and Hui Li. 2024. Prompt-enhanced software vulnerability detection using chatgpt. In *Proceedings of the 2024 IEEE/ACM 46th International Conference on Software Engineering: Companion Proceedings*. 276–277.
- [122] Jie Zhang, Haoyu Bu, Hui Wen, Yongji Liu, Haiqiang Fei, Rongrong Xi, Lun Li, Yun Yang, Hongsong Zhu, and Dan Meng. 2025. When llms meet cybersecurity: A systematic literature review. *Cybersecurity* 8, 1 (2025), 55.
- [123] Jie Zhang, Haoyu Bu, Hui Wen, Yongji Liu, Haiqiang Fei, Rongrong Xi, Lun Li, Yun Yang, Hongsong Zhu, and Dan Meng. 2025. When llms meet cybersecurity: A systematic literature review. *Cybersecurity* 8, 1 (2025), 55.
- [124] Jian Zhang, Chong Wang, Anran Li, Weisong Sun, Cen Zhang, Wei Ma, and Yang Liu. 2025. Evaluating Large Language Models for Line-Level Vulnerability Localization. *IEEE Transactions on Software Engineering* (2025).
- [125] Lan Zhang, Qingtian Zou, Anoop Singhal, Xiaoyan Sun, and Peng Liu. 2024. Evaluating Large Language Models for Real-World Vulnerability Repair in C/C++ Code. In *Proceedings of the 10th ACM International Workshop on Security and Privacy Analytics*. 49–58.
- [126] Shaobo Zhang, Qianzhi Wang, Qin Liu, Entao Luo, and Tao Peng. 2026. VulTrLM: LLM-assisted vulnerability detection via AST decomposition and comment enhancement. *Empirical Software Engineering* 31, 1 (2026), 1–36.
- [127] Xinyu Zhang, Siddharth Muralee, Sourag Cherupattamoolayil, and Aravind Machiry. 2024. On the effectiveness of large language models for github workflows. In *Proceedings of the 19th International Conference on Availability, Reliability and Security*. 1–14.
- [128] Xin Zhou, Sicong Cao, Xiaobing Sun, and David Lo. 2024. Large Language Model for Vulnerability Detection and Repair: Literature Review and the Road Ahead. *ACM Trans. Softw. Eng. Methodol.* (2024). Just Accepted.
- [129] Xin Zhou, Ting Zhang, and David Lo. 2024. Large language model for vulnerability detection: Emerging results and future directions. In *Proceedings of the 2024 ACM/IEEE 44th International Conference on Software Engineering: New Ideas and Emerging Results*. 47–51.
- [130] Yuan Zhou, Enze Wang, and Shuoyoucheng Ma. 2025. SSRFSeek: An LLM-based static analysis framework for detecting SSRF vulnerabilities in PHP applications. In *2025 IEEE 6th International Seminar on Artificial Intelligence, Networking and Information Technology (AINIT)*. IEEE, 939–944.
- [131] Jin Zhu, Hui Ge, Yun Zhou, Xiao Jin, Rui Luo, and Yanchen Sun. 2024. Detecting Source Code Vulnerabilities Using Fine-Tuned Pre-Trained LLMs. In *2024 IEEE 17th International Conference on Signal Processing (ICSP)*. IEEE, 238–242.

A Models, Languages, and Datasets of the Reviewed Studies

Table 6. Models, programming languages, and datasets used in studies of vulnerabilities introduced by LLM-generated code (RQ1).

Paper	Models	Languages	Datasets
Liu et al. [64]	GPT (3.5, 4)	C, C++, Java, JavaScript, Python	mixed/curated - 728 LeetCode problems + 54 CWE scenarios
Khoury et al. [47]	ChatGPT-3.5	C, C++, HTML, Java, Python	manually constructed - 21 programs
Asare et al. [8]	GitHub Copilot (Codex)	C, C++	pre-existing benchmark - Big-Vul (3,754 vulnerabilities)
Perry et al. [83]	GitHub Copilot (Codex)	C, JavaScript, Python	user study tasks (no dataset)
Sandoval et al. [90]	GitHub Copilot (Codex)	C, C++	user study tasks (no dataset)
Pearce et al. [81]	GitHub Copilot	C, Python, Verilog	manually constructed - 1,689 programs
Siddiq et al. [94]	GPT (3.5, 4), CodeGen (2B-mono, 2.5- 7B-mono), StarCoder	Python	manually constructed - SALLM (100 prompts)
Hajipour et al. [33]	CodeGen-6B, ChatGPT, Code Llama 13B, StarCoder-7B, WizardCoder-15B	C, Python	manually constructed - CodeLMSec (280 prompts)
He et al. [35]	CodeGen (350M, 2.7B, 6.1B)	C, C++, Python	mixed/curated - SVEN (1,606 programs; 9 CWEs)
Siddiq et al. [95]	InCoder (6.7B), GitHub Copilot	Python	mixed/curated – SecurityEval (130 programs)
Tóth et al. [105]	GPT-4	PHP	manually constructed - ChatPHP-DB (2,500 programs)
Hamer et al. [34]	GPT-3.5-turbo-0613	Java	manually constructed (216 code snippets)
Rabbi et al. [87]	GPT-3.5-turbo	Python	pre-existing - DevGPT (1,756 code snippets)
Fu et al. [27]	GitHub Copilot, Code-Whisperer, Codeium	JavaScript, Python	manually constructed - 733 code snippets
He et al. [36]	StarCoder (1B, 3B), Code Llama 7B, Phi-2-2.7B, Llama 2-7B, Mistral-7B	C, C++, Go, Java, JavaScript, Python, Ruby	automatically constructed – SafeCoder (1,268 programs, includes SVEN)
Gong et al. [31]	GPT (3.5-turbo-0125, 4-0613), Code Llama 70B, CodeGeeX2-6B	Python	pre-existing benchmark - SecurityEval (130 programs)
Jamdade et al. [41]	ChatGPT	TypeScript	case study tasks (no dataset)
Aydin et al. [9]	GPT-4o, Claude v3.5 Sonnet, DeepSeek R1 70B, Llama 3.1 405B, Mistral Large 2, Nova Pro	JavaScript	case study tasks (no dataset)

Table 7. Models, programming languages, and datasets used in LLM-based vulnerability detection studies (RQ2).

Paper	Models	Languages	Datasets
Zhang et al. [121]	GPT-4	C, C++, Java	SARD, NVD (total 2,088 Java and 1,937 samples)
Bakhshandeh et al. [11]	GPT-3.5-Turbo	Python	SecurityEval (130 files), PyT (26 files)
Mohajer et al. [71]	GPT (3.5 Turbo, 4)	Java	Nacos, Azure-maven-plugins, Playwright-java, Java-debug, DolphinScheduler, Dubbo, Bundletool, Guava, JReleaser (sizes not stated)
Ullah et al. [108]	GPT (3.5, 4), PaLM 2, Llama 2, StarCoder+	C, Python	GPAC, libtiff, Linux, PJSIP (sizes not stated)
Zhou et al. [129]	GPT (3.5, 4)	C, C++	Data not stated
Shestov et al. [93]	WizardCoder	Java	curated, VCMATCH, CVEfixes (sizes not stated)
Purba et al. [85]	GPT-3.5-Turbo, Davinci, CodeGen-2B-multi model	C, C++, Go, JavaScript, Python	Code gadgets, CVEfixes (sizes not stated)
Thapa et al. [100]	GPT (2, J), MegatronGPT-2	C, C++	VulDeePecker, SeVC (NVD and SARD) (sizes not stated)
Tamberg et al. [98]	GPT (4, 4-turbo), Claude 3 Opus	Java	Java Juliet 1.3 (578 files)
Ding et al. [22]	GPT (3.5, 4), StarCoder2, CodeGen2.5	C, C++, Python	PrimeVul (6,968 vulnerabilities) - proposed, BigVul (size not stated) - case study
Çetin et al. [15]	GPT (3.5, 4), Claude, Gemini, Llama 2,	PHP	SARD (86 samples), curated (11 samples)
Zhang et al. [124]	GPT (3.5, 4), Llama 2, Code Llama, WizardCoder, CodeGen	C, C++, Solidity	BV-LOC (10,811 functions), SC-LOC (1,369 functions)
Wen et al. [112]	GPT-3.5 (turbo, instruct), Llama (7B, 13B), Code Llama (7B, 13B)	C, C++	curated - VulEval (232,239 functions)
Bae et al. [10]	GPT (3.5-turbo, 4o), Claude 3.5 Sonnet	C++, Java, Python	SARD (91 cases)
Li et al. [53]	GPT (3.5, 4)	C	UBITect (22 cases)
Yang et al. [118]	GPT (3.5-turbo-0125)	not stated	Chrome (3,939), Linux (1,961), Android (1,277), QEMU (125) vulnerabilities
Guo et al. [32]	GPT-4, Code Llama (7B, 13B), Mistral 7B, Mixtral-8x7B	C, C++	curated (13,532), Devign (27,318), Lin2017 (621), Choi2017 (14,000), LineVul (18,864), PrimeVul (25,908) functions
Li et al. [58]	GPT-4	Java	curated - CWE-Bench-Java (120 vulnerabilities)
Ni et al. [74]	GPT-3.5 turbo	C, C++	MegaVul (736 projects)
Li et al. [54]	GPT (3.5-turbo, 4), Bard, Claude 2	C	curated (1,000 cases)
Ozturk et al. [78]	ChatGPT	PHP	constructed (92 vulnerabilities)

Paper	Models	Languages	Datasets
Yu et al. [120]	DeepSeek (Coder, R1), Code Llama, Llama 3.1, ChatGPT, QwQ-plus	C, C++, C#, Go, Java, JavaScript, Python	REEF (20,165 functions)
Mechri et al. [69]	CodeQwen1.5-7B	Python	
Anbiya et al. [6]	DeepSeek-R1-Distill-Qwen-7B, Qwen/Qwen2.5-Coder-7B-Instruct	Java	SARD + CVEfixes (9,804 snippets)
Wang et al. [111]	Code Llama 7B, GPT (3.5, 4)	Java	MegaVul (12,920 instances), Juliet (756 samples), constructed (640 samples)
Jiao et al. [42]	Llama 3.1 (8B, 70B, 405B), DeepSeek (V3, R1)	C, C++	NVD (1,937 snippets)
Zhang et al. [126]	Qwen2.5 (7B-Instruct, Coder-7B-Instruct), DeepSeek-v2.5	C, C++	FFmpeg+QEMU (22,361 functions), Reveal (18,169), SVulD (28,730)
Xu et al. [115]	GLM-4-flash, DeepSeek-v3, GPT-3.5-turbo	C, C++	InterPVD (547 cases)
Chen et al. [17]	Qwen-Plus	C, C++	SlicedLocator (18,062 programs)
Munson et al. [72]	GPT (4, 4o-mini), Claude 3.5 Sonnet, o1 (preview, mini)	Java	OWASP Benchmark v1.2 (2,740 test cases)
Li et al. [57]	GPT (3.5-turbo, 4-turbo), Llama 3 8B, Llama 3.1 (405B, 8B), Code Llama (13B, 7B), Gemma 7B, CodeGemma 7B, CodeQwen1.5 7B, Mixtral 7B	C	constructed - SV-TrustEval-C (377 files)
Curto et al. [20]	Llama 3 8B, Code Llama 7B	C, C++	BigVul (14,178 functions), DiverseVul (17,100 functions)
Sovrano et al. [96]	GPT (3.5-turbo, 4-turbo, 4o), Llama 3 70B, Mixtral-8x (22B, 7B)	C, Go, HTML, Java, JavaScript, PHP, Python, Ruby, TypeScript	CVE entries (1,588 files)
Xia et al. [114]	GPT (3.5-turbo, 4-turbo), Gemini-1.0-Pro, Code Llama-34B-Instruct, DeepSeek-Coder-33B-Instruct	Java, Python	CryptoAPI-Bench (153 GTMs), MASC minimal test suites (37 cases)
Jensen et al. [40]	GPT (3.5-turbo, 4), text-Davinci-003, Falcon-7B-Instruct, Llama-2 (7B-chat, 13B-chat), Dolly-v2 (3B, 7B, 12B)	Python	HumanEval (148 functions), MBPP (476 functions), SecurityEval (36 functions)
Gneciak et al. [30]	GPT-4.1, Mistral Large, DeepSeek V3	C#	constructed (63 vulnerabilities)
Saimbhi et al. [89]	GPT-3.5-turbo	PHP	constructed (17 vulnerability types)
Zhu et al. [131]	Qwen2-7B	Java	SARD (8,353 test cases)
Li et al. [56]	CodeGemma (7B, 7B-it), Code Llama (7B, 7B-it), Llama 2 (7B, 7B-chat), Llama 3.1 (8B, 8B-it)	C, C++, Java, JavaScript, Python, Go	curated - SynData (15,572), Real-Data (size not stated)

Paper	Models	Languages	Datasets
Lin et al. [59]	GPT-4, Llama 2 (7B, 13B, 70B), Code Llama (7B, 34B, 70B), Llama 3 (8B, 70B), Mistral 7B, Mixtral 8×7B, Gemma (2B, 7B), CodeGemma 7B, Phi-2 2.7B, Phi-3 3.8B mini	Java	Vul4J (140 files)
Chen et al. [16]	GPT-4o	Java	Juliet + curated (382 instances)
Liu et al. [63]	GPT-3.5-turbo	C, C++, Java	Devign (1,943 samples)
Liu et al. [65]	GPT-3.5-turbo	C, C++	Devign (1,943 functions), ReVeal (1,400 functions)
Maligazhdarova et al. [67]	GPT-4o-mini	C, C++	curated SQLi (514 samples), manually constructed NoSQLi (103 samples)
Rafique et al. [88]	Llama 3.2-1B-Instruct, Deepseek-llm-7B-Base	not reported	Draper VDISC (12,954 samples)
Trad et al. [107]	GPT-4o-mini	C (majority)	public test set (2,706 functions)
Khare et al. [45]	GPT (3.5-turbo, 4), Gemini-1.5-Flash, Qwen2.5-Coder (1.5B, 7B), Qwen2.5 (14B, 32B), DeepSeekCoder (7B, 33B), DeepSeekCoder-V2-15B, Llama 3.1 (8B, 70B), Code Llama-Instruct (7B, 13B, 34B), Codestral-22B	C, C++, Java	OWASP (2,740 snippets), SARD Juliet 1.3 (81,280 functions), CVE-Fixes C/C++ (19,576 functions), CVEFixes Java (3,926 functions)
Huynh et al.[38]	GPT (3.5, 4o), Gemini 2.0 Flash, Meta Llama 3.1 8B	C, C++	DiverseVul (330,492 functions)
Li et al. [55]	CodeGemma 7B-it, Code Llama 7B-it, Llama 3.1 8B-it	C, C++	SynData (31,144 functions), FFmpeg+Qemu+Reveal (size not reported)
Tian et al. [101]	Code Llama 7B, Claude 3.5 Sonnet, DeepSeek-R1	not reported	SVEN (803 samples), MegaVul (169 CWE IDs, 8254 CVE IDs), SafeCoder (1211 vulnerabilities), manually constructed (327 CVEs)
Zhou et al. [130]	DeepSeek R1	PHP	real-world projects (≈868 files)
Ibanez-Lissen et al. [39]	Gemma 2B	C, C++	DiverseVul (217,007 samples), BigVul (188,636 samples), PrimeVul (74,894 samples)
Qiu et al. [86]	GPT-4o, Qwen3-32B, Code Llama 70B, DeepSeek-R1-Distill-Llama 70B, Llama 3.1 70B, DeepSeek-R1, Doubao	C, C++	FFmpeg+QEMU (27,318 functions), DiverseVul (309,387 functions)
Lin et al. [60]	GPT-4, Llama 2 (7B, 13B, 70B), Code Llama (7B, 34B, 70B), Llama 3 (8B, 70B), Mistral 7B, Mixtral 8×7B, Gemma (2B, 7B), CodeGemma 7B, Phi 2.7B, Phi-3-mini 3.8B	C, C++, Java	Vul4J (280 files), BigVul (200 files)
Carletti et al. [14]	Code Llama 7B, StarCoder 7B	C, C++	DiverseVul (26,189), BigVul (14,068), Devign (2,232), Debian (1,885), PrimeVUL (882) samples

Paper	Models	Languages	Datasets
Kouliaridis et al. [50]	GPT (3.5, 4, 4-turbo), Code Llama, Llama-2, Zephyr (Alpha, Beta), Nous Hermes Mixtral, MistralOrca	Java	constructed - Vulcorpus (100 samples)
Mao et al. [68]	GPT-3.5, DeepSeek-V3, Code Llama 13B-Instruct	C, C++	SeVC (15,592 functions), DiverseVul (18,945 functions), PrimeVul (6,969 functions)

Table 8. Models, programming languages, and datasets used in LLM-based vulnerability fixing studies (RQ2).

Paper	Models	Languages	Datasets
Pearce et al. [82]	code-cushman-001, code-davinci (001, 002), J1 (jumbo, large PolyCoder), GPT-2-csrc	C, C++, Python, Verilog	ExtractFix (12 CVEs), synthetic scenarios (117), hand-crafted scenarios (7)
Zhang et al. [125]	GPT-4, Claude	C, C++	manually constructed (223 snippets)
de-Fitero-Dominguez et al. [21]	Code Llama, Mistral	C, C++	Big-Vul + CVEFixes (6,088 samples)
Wu et al. [113]	Codex, CodeGen, InCoder	Java	curated - VJBench (42), VJBench-trans (150), existing - Vul4J (35) vulnerabilities
Kulsum et al. [51]	GPT-3.5-turbo	C, Java	ExtractFix (10 CVEs), VJBench (15 vulnerabilities), Vul4J (35 vulnerabilities)
Wang et al. [109]	GPT (3.5-Turbo, 4o), DeepSeek-Coder, Code Llama, Llama 3	C, C++, C#, Go, Java, JavaScript, Python	REEF (30,987 vulnerability-fix pairs)
Le et al. [52]	ChatGPT, Bard	JavaScript	manually constructed - (20 vulnerabilities)
Antal et al. [7]	GPT (4, 4o)	Java	Vul4J (42 vulnerabilities)
Braconaro et al. [13]	GPT-4o, Gemini 1.5 Flash, Gemini	Java	proposed (272 violations)
Tihanyi et al. [104]	GPT-4o	C	FormAI C ($\approx$ 500 programs)
Tao et al. [99]	GPT-4o, Qwen-2.5, Llama 3, Code Llama, Phi-1.5	C, C++	BigVul (11,823 functions)
Firouzi et al. [24]	GPT-3.5	Java	Stack Overflow posts
Wang et al. [110]	GPT (3.5-turbo, 4-turbo), Gemini 2.5 Pro, DeepSeek-Coder-6.7B-Instruct, Magicoder-S-DS-6.7B	C, C++	CVEFixes (547 vulnerabilities)
Liu et al. [61]	GPT (3.5-turbo-0301, 4-0314)	not stated	ExtractFix, PatchNet, Panther, Quatrain, Invalidator (total 70,346 samples)
Khan et al. [44]	GitHub Copilot	C, C++	curated (156 snippets)
Nong et al. [76]	GPT-4-turbo, Gemini-1.5 Pro, Claude-3.5 Sonnet, Llama-3.1-70B	C	ExtractFix (20 vulnerabilities), Zero-Day dataset (97 vulnerabilities)

Paper	Models	Languages	Datasets
Kim et al. [48]	GPT (4o, 4o-mini, 3.5-turbo), Claude 3.5 Sonnet, Gemini 1.5 (Pro, Flash)	C, C++	OSS-Fuzz (547 vulnerabilities)
Liu et al. [62]	GPT (3.5, 4)	C, C++	datasets not stated

Table 9. Models, programming languages, and datasets used in studies that combine LLM-based vulnerability detection and fixing (RQ2).

Paper	Models	Languages	Datasets
Zhang et al. [127]	GPT-3.5, Code Llama, Star-Chat	YAML	curated ($\approx$ 400K GitHubworkflows)
Fu et al. [26]	GPT (3.5, 4-turbo)	C, C++	BigVul + CVEFixes ($\approx$ 190k functions)